



SECURITY MASTER PLAN

Muhammad Anas Bin Naeem,
Muhammad Taha Saeed,
Mohamed Taha Makki

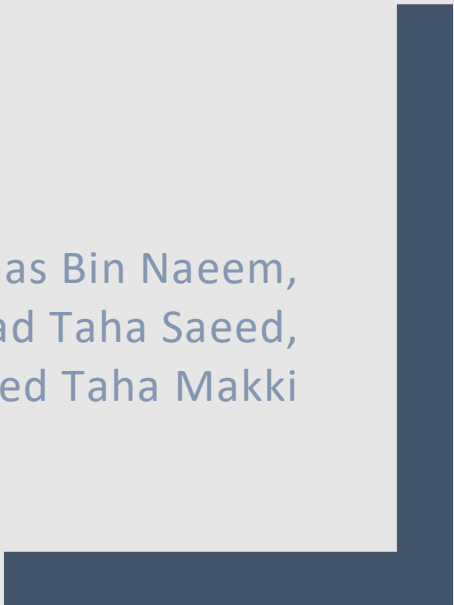


Table of Contents

Introduction	3
1.0 Organization Software Related threats.....	4
Threat – Phishing Attack	4
Threat 2- DOS Attack.....	5
Threat 3 – Social Engineering	6
Threat 4 - Ransomware:	7
Threat 5 – Intellectual property (IP) theft:	8
Threat 6 – Software vulnerabilities:.....	11
Threat 7 – Inadequate backups and disaster recovery:	14
Threat 8 – Insecure development and test environments:	15
Threat 9 – Data Corruption Due to Software Bugs	18
Threat 10 – Unauthorized Software Changes	20
2.0 Organization physical threats.....	22
Threat 1- Intrusion:	22
Threat 2 – Fire.....	24
Threat 3 - Power outage.....	25
Threat 4 - Natural disasters	27
Threat 5 – Unauthorized Physical Access to Server Room	28
Threat 6 – Hardware Failure	30
Threat 7 - Temperature rise in critical areas.....	31
Threat 8 – Unauthorized Access via Wireless Networks	33
3.0 Organization People Related threats	34
Threat 1 – Social engineering	34
Threat 2 – Phishing	35
Threat 3 – Insider attacks	36
Threat 4 – Poor security practices	38
Threat 5 – Password Sharing	39
Threat 6 – Untrained Part-time Staff	41
Threat 7 – Lack of Proper Offboarding Procedures.....	42
Threat 8 – Social Media Threats	43
Threat 9 – Unintentional Data Leakage.....	45
Threat 10 – Incompetent Staff or Team	46
4.0 Organization Policies and Procedures Threats	47
Threat 1 - Weak Password policies	47

Threat 2 – Physical security policies	48
Threat 3 – Visitor policies.....	50
Threat 4 – Software policies	51
Threat 5 – Lack of Data Backup and Recovery Procedures	53
Threat 6 – Absence of Incident Response Plan.....	54
Threat 7- Lack of System Monitoring and Security Audits procedures.....	55
Threat 8 – Lack of Employee Security Training.....	56
Threat 9 – Inconsistent Data Classification and Handling Procedures.....	58
Threat 10 – Lack of Disaster Recovery and Business Continuity Plan.....	60
5.0 Best Practices for Implementing Identified Controls	62
5.1 Minimum Due Diligence	70
5.2 Key Considerations.....	74
5.3 Metrics and Measurements.....	75
6 Asset Evaluation Table	78
7 Asset-weighted factor analysis	98
8 Ranked Risk Vulnerability Assessment Table	102
9 Cost Benefit Analysis Table	109
10 Risk Control Strategy.....	117
References.....	148

Company: Energy Labs

Members:

1. Muhammad Anas Bin Naeem – CEO & legal officer.
2. Muhammad Taha Saeed – CSO & Director of the back office.
3. Mohamed Taha Makki – CIO & Director of sales.

Introduction

This is the security master plan proposed by Energy Labs to secure and protect its critical and valuable assets.

This document comprehensively analyzes potential threats and vulnerabilities an organization may face across multiple domains: software, physical infrastructure, personnel, and policy frameworks. Its primary purpose is to identify these threats, assess their impact, and propose effective mitigation strategies to safeguard operational continuity, data integrity, and organizational reputation.

The structure is methodically divided into sections that address software-related risks like phishing, ransomware, and vulnerabilities; physical threats such as unauthorized access, natural disasters, and hardware failures; people-related threats like insider attacks and untrained staff; and policy-related threats including weak password policies and insufficient incident response plans.

Additionally, the document provides best practices for implementing control measures, asset evaluation, and cost-benefit analyses to prioritize and manage risks effectively. It culminates in strategies for risk control to ensure resilience against identified threats.

This resource aims to guide organizations in creating robust security frameworks and response mechanisms to mitigate risks while aligning with industry standards and best practices.

1.0 Organization Software Related threats

Threat – Phishing Attack

Assumption

All employees use email and the internet which leaves them prone to phishing attacks. Phishing attacks are also increasingly widespread and common.

1.2% of all emails are malicious which equals to 3.4 billion phishing emails daily. Every year, 83% of all organisations face phishing attacks. (Saxena, 2024)

Example

An example could be that the staff receives an email from their competitor or at least looks like it's from their competitor requesting information about a software bug and includes a link to a website. Most likely, that link goes to a malicious website. If the staff clicks on that link, they unknowingly provide their login credentials, which the attacker can then use to access the company's systems. This breach could lead to unauthorized access to sensitive client data, such as seismic data, or proprietary software, such as the source code for the new **SensorDrill** upgrade.

Impact

It can have a big impact if a support staff member or even a client falls victim to a phishing attack; it could lead to unauthorized access to client systems, exposing sensitive client data, and potentially compromising the company's reputation.

Mitigation

Employee Training: Conduct regular phishing awareness training for all support staff to help them recognize and avoid phishing attempts. This should include simulated phishing exercises to reinforce learning.

Use software like **Cofense PhishMe** to simulate phishing attacks and train employees on how to identify phishing attempts.

Email Filtering: Use **Barracuda Email Security Gateway** (Model 300) to block phishing emails before they reach staff inboxes. This hardware email security appliance provides advanced threat detection, filters malicious content, and can be integrated with existing email servers.

Threat 2- DOS Attack

Assumption

The organization's reliance on real-time monitoring systems like SensorDrill and MeasureMe makes it highly vulnerable to DoS attacks. Such attacks can overload critical servers supporting client-facing portals, leading to downtime and delays in oil and gas well monitoring.

Example

The attacker can target the company's customer support portal with a DoS attack, overwhelming the servers with a flood of traffic. As a result, the portal becomes unavailable to legitimate users. Clients relying on the company's support services for critical issues, such as problems with the "SensorDrill" or "MeasureMe" software, are unable to get the help they need, causing significant disruptions to their operations and potentially damaging the company's reputation.

Impact

This could lead to significant downtime, preventing support staff from assisting clients, damaging the company's reputation, and potentially leading to financial losses due to service disruptions.

Mitigation

Traffic Monitoring: Deploy network monitoring tools such as **Cisco Firepower 1120 Series** that can detect abnormal traffic patterns and protect against a DoS attack. The **Cisco Firepower 1120** model provides real-time traffic analysis and automated responses to abnormal traffic spikes.

Rate Limiting: Rate limiting is the practice of limiting the amount of traffic available to a specific Network Interface Controller (NIC). It can be done at the hardware or software level to mitigate the chances of falling victim to a DoS attack (Developer, n.d.). Implement rate limiting with **Cloudflare**, which is a cloud-based solution that offers rate-limiting services to protect web applications. It can be configured manually to limit the number of requests from individual users, minimizing the impact of a DoS attack on the **customer support portal**.

Threat 3 – Social Engineering

Assumption

Employees, particularly in sensitive departments like R&D and Data Processing, are prime targets for social engineering attacks. These attacks aim to exploit employees' trust through impersonation or pretexting, often leading to unauthorized access to confidential data about seismic processing or future upgrades to SensorDrill.

Studies reveal that 98% of cyberattacks involve some element of social engineering. Additionally, 60% of small to medium enterprises (SMEs) report falling victim to social engineering attacks annually. (Kaspersky, 2023)

Example

An attacker calls a member of the **Research and Development (R&D)** team, acting as a high-level executive, requesting access to proprietary information about the new **real-time monitoring feature** for the **SensorDrill** system. The employee provides access to sensitive R&D files without properly verifying that it is a high-level executive within the company, potentially exposing critical company data to competitors.

Impact

If attackers gain access to confidential R&D information, such as progress on **Project 1** or plans for future upgrades to **Shake and Quake**, it could result in competitive disadvantages. **Another Company, Pty Ltd**, could use this information to close the technological gap of 2 years, jeopardizing market share and revenue.

Mitigation

Check the source: Establish a verification process for all requests involving access to sensitive information or systems. For instance, with an email, look at the email header and check against valid emails from the same sender. Look at where the links go - spoofed hyperlinks are easy to spot by simply hovering your cursor over them (Kaspersky, n.d.). Deploy **Okta Identity Cloud** for Multi-Factor Authentication (MFA) and secure access to sensitive data. Okta ensures that access to important resources is only granted after verifying the identity of the requestor through multiple authentication factors.

Security Awareness Training: Provide comprehensive training on social engineering techniques, including how to recognize and respond to such attacks.

Access Controls: Limit the number of employees who have access to sensitive progress reports. Ensure that access is granted only on a need-to-know basis and is regularly reviewed. Implement **Microsoft Azure Active Directory (AD)** for Role-Based Access Control (RBAC). This ensures that only authorized personnel can access sensitive files, and regular audits of access logs can be conducted through **Microsoft Azure Security Center** to detect unauthorized access attempts.

Threat 4 - Ransomware:

Assumption

The reliance on seismic data processed by Shake and Quake and proprietary software development makes the company a major target for ransomware attackers, who exploit vulnerabilities to lock critical data and ask for huge sums of money.

Example

A ransomware attack targets the **Data Processing Department**, encrypting all seismic data processed using **Shake and Quake**. The attackers demand a large ransom for the decryption key, preventing the company from delivering seismic reports to clients like those involved in the **oil and gas industry**. The company is faced with the difficult decision of either paying the ransom or losing vital data.

Impact

Ransomware could lead to the loss of critical client data, delaying projects and reducing trust in the company's ability to deliver services. The financial impact could be severe, with potential ransom payments, legal liabilities, and lost business opportunities.

Mitigation

Regular Backups: Backing up all files and data regularly means you won't lose existing assets in the event of a ransomware attack and can restore your systems (Centre, 2022). Ensure backups are stored offline or in a secure cloud environment to prevent them from being affected by ransomware. **Use Dell EMC Data Domain 3300** for automated, secure backups of seismic data. This solution offers data deduplication and ensures backups are stored in a secure, offline environment to protect against ransomware attacks.

Anti-Ransomware Tools: Deploy anti-ransomware software such as **Sophos Intercept X** with **EDR** to monitor for ransomware attacks on all workstations and servers in the departments.

Threat 5 – Intellectual property (IP) theft:

Assumption

SensorDrill, MeasureMe and Shake and Quake are proprietary closed source software that is owned by the company. It is an IP of the company which could be stolen if the source code is leaked or breached.

Example

IP theft is a potential threat that can cause significant damage to the business unit and the company. The company has its own specialized software which is SensorDrill, MeasureMe, Shake, and Quake which is its intellectual property. The security of these IPs is important and there are many possible threats.

Impact

If any attackers gain access to the software's source code or designs, they could release a similar product or release it to competitors or the public. This will result in a loss of market share and revenue as competitors and the public will be able to use the company's special software without licensing it from the company. The company will lose its competitive edge and attackers may even modify the software to make it malicious for attacking the company's clients who use their software. This will cause a loss of reputation for the company.

Mitigation

Mitigations against this threat can be access controls to ensure that only authorized personnel can access sensitive project files. Access control can also ensure that only the authorized software developers and other team members who are working on the software are allowed to access the code base.

Role based access control should be used here as permissions are assigned based on roles and each role provides access rights. This can be used to ensure that only developers who are working on the applications have access to the source code and not other departments like sales or marketing who do not need to view source code files.

Microsoft Azure Active Directory (AD) is deployed and installed on to provide role-based access control. It is a directory and identity management service that operates in the cloud and offers authentication and authorization services to various Microsoft services and third-party services.

This ensures that only those who actually need to work with the applications can access the intellectual property. The chances of accidental or malicious exposure are reduced. Unauthorized employees won't be able to access or steal sensitive files since the system limits what they can view.

Encryption can be applied on sensitive documents related to the software and its development. This ensures that any unauthorized third party who gets access to the software files cannot read it. AES-256 can be used to encrypt the data at rest in the devices and servers. AES is a robust and industry standard encryption algorithm that provides strong and efficient encryption. Even if the data is leaked it will be unreadable to unauthorized third parties.

For data in transit over the company networks or other mediums, TLS can be used to encrypt it and prevent attackers from intercepting and reading sensitive IP or authentication credentials as they travel between users, applications, and servers.

Bitlocker can be used on the windows devices to encrypt the entire disk. This helps in situations where if an employee's device is stolen or lost, the data stored on the disk remains encrypted and inaccessible without proper authentication.

Regularly monitoring and auditing access logs to detect any unauthorized access attempts. This allows any unusual activities or behaviours to be reported and investigated. A security information and event management tool like Splunk can be used for monitoring logs, detecting unusual activities, and providing real-time alerts.

Splunk can detect if there are large amounts of confidential information being transferred to external IPs by an employee and trigger alerts.

Intrusion detection systems (IDS) like the open-source snort will be used to detect and analyse network traffic. It can be used to log and block any suspicious activity while generating alerts for system Admins.

The **Cisco Firepower 1120 Series** firewall will be installed. This next generation firewall utilizes machine learning to identify threats and malware in applications. It has high performance and throughput of 45 GBps. It can be deployed as both a firewall or an IPS. This firewall will protect the applications and their source code. It will prevent any outsiders from trying to access or break into company networks or applications and will also stop any potential insiders from engaging with malicious third parties.

This robust firewall will also reduce the frequency and damage of SQL injections, buffer overflows and XSS as any malicious IPs will be blocked. Any the IPS mode will detect and prevent any attempts to exploit known and common vulnerabilities.

Threat 6 – Software vulnerabilities:

Assumption

The company's software and database are vulnerable to different software based attacks like SQL injection, buffer overflows, XSS and more.

SQL injections were found to be 23.4% of web application vulnerabilities and XSS was found to be 19.1% of web application vulnerabilities. (Statista, 2024)

This is why software vulnerabilities have been considered as a critical threat to the organisation.

Example

There could be threats to the software and software systems that the company is developing for monitoring and data processing. Vulnerabilities like SQL injection, buffer overflows and XSS within these software systems may exist and could be exploited by attackers to gain unauthorized access, disrupt operations, or manipulate data.

Impact

This could lead to system failures, inaccurate data reporting, and loss of client trust, affecting the company's reputation and operational efficiency. The software will become unreliable and give inaccurate results and so it will no longer be useful for clients. This will cause a loss of company market share, revenue and reputation.

Software vulnerabilities are a big weakness that must be patched to ensure smooth development of the organization's applications and projects as well as client satisfaction.

Mitigation

Mitigations against this threat include using secure coding practices. Applying the best practices and principles while developing the company software to ensure it is reliable, useful and secure to avoid any vulnerabilities and bugs. This can include regular code reviews and analysis, code testing for all possible cases and edge cases and adherence to the industry security standards and best practices.

For sql injections, parametrized queries can be used as a mitigation. These separate SQL logic from the input data. This prevents user inputs from being interpreted as SQL commands.

Web application firewalls like cloudflare, Azure WAF or AWS WAF can be deployed to prevent sql injections attacks in real time. They filter, monitor, and block malicious SQL queries before they reach the database.

The organization can create custom rules specific to their applications. If a particular field is frequently targeted by SQLi, a WAF rule can be applied to block any suspicious input for that specific field. They can also send alerts to system admins if any suspected attacks or attempts are occurring.

Preventing buffer overflows requires input validation and bounds checking. The developer teams must ensure that the length of the input is always checked against the buffer size, and do not allow inputs to exceed buffer limits.

Stack canaries can also be used which are small secret values placed in memory. When a buffer overflow overwrites the canary, it triggers an error before the return address can be altered. This should be done by the dev teams.

One more technique is Address Space Layout Randomization (ASLR) which randomises the location of processes in memory, making it harder for attackers to predict the memory location of injected malicious code.

The developer and IT teams must implement these secure programming practices to safeguard the applications against all types of different software vulnerabilities and exploits that attackers can try.

Regularly providing update and patches for the software to fix known vulnerabilities. Ensuring that updates are tested carefully in a controlled environment before deployment to avoid introducing any new issues. Company policies should be created to ensure that the applications the employees are using are always updated with the latest security patches. The company's own applications should also regularly be tested internally by their developer and testing teams as well as externally through other security and pen testing consultants atleast once in 6 months.

Regular vulnerability testing. Implement regular vulnerability scanning and penetration testing to identify and address potential security weaknesses in the software. Vulnerability scanning tools like acunetix can be used to quickly scan through and find any exploits or weaknesses in the company's web apps. Nessus is another trusted and reliable security scanner. Qualysguard is a cloud-based security scanner that is highly scalable. The company should utilize one or multiple of these security scanners to

ensure all aspects of security are covered to prevent damage from all angles in the software attack surface.

Threat 7 – Inadequate backups and disaster recovery:

Assumption

Backup failures can be common if they aren't setup correctly. 26% of backup and recovery fail. 60% of backups are found to be incomplete and 50% of restores fail. (*The Failure of Backups and Restores: A Growing Concern in Data Management*, n.d.)

This is why incorrectly setup backup procedures are a threat that can cause significant damage to the organisation if their backup plans do not succeed.

Example

Insufficient backup and disaster recovery plans can be a big risk for the R & D business unit. There can be a risk of losing valuable project data, including source code, research, and client data.

Impact

This could be caused by many factors like hardware failures, accidental deletions, or any attacks or vulnerabilities exploited by attackers. This Data loss can result in project delays, loss of intellectual property, and significant recovery costs. This will damage the company's reputation, market share and revenue.

Regular full data backups are necessary or else crucial data will be constantly at risk of deletion, corruption or breaches.

Mitigation

This can be mitigated by having regular backups. Implementing a well-planned backup strategy that involves regular backups of all critical data like the source code, documentation, and research files.

Data can be backed up locally on dedicated backup servers that are offsite and separate from the main servers. Data can be backed up on the cloud like Amazon's AWS or Microsoft's Azure.

Backup solutions like Veeam can be deployed for data backup and replication. Backup and recovery methods and procedures should be regularly tested and updated to ensure they are reliably backing up the data.

If required, hot sites or cold sites can be set up. Hot sites that will replicate the entire infrastructure of the organization so operations can resume immediately in case of any serious disasters. Cold sites can be used to temporarily work with a limited setup if the damage to the main sight is not serious and is repairable.

A disaster recovery plan should also be developed, which outlines the steps to be taken in the event of a data loss, system failure, or cyber-attack. The disaster recovery team should create comprehensive plans and policies that detail all steps to be taken in case of any kind of disasters or unexpected events to minimize damage to the organisation's information, devices, employees and other assets.

Threat 8 – Insecure development and test environments:

Assumption

There are separate development environments for the project and the software the company works on. There will be a development and testing environment where the developers are modifying and upgrading the software and testing different changes to ensure the software continues operating smoothly.

There is the live production environment where the software builds are used by the clients.

Example

Development and testing environments are less secure than the production and live environment. This can cause problems during the development and testing of the company's software and other research projects.

Impact

If these environments are not properly secured, they can expose vulnerabilities or sensitive information that can be exploited by attackers. This can also lead to issues where vulnerabilities are discovered too late in the development cycle which will impact the overall quality and security of the software.

This causes software vulnerabilities like the Sql injection, buffer overflows, Xss and more to arise. These vulnerabilities will compromise the applications of the organization. Attackers may take advantage of exploits to gain access to the software, its source code or the data that these applications process and use. This will cause numerous problems like data leaks, Ip theft if the source code is leaked or compromised and data deletion or corruption.

Client data being compromised will also result in legal and reputational consequences for the organization.

Mitigation

This can be mitigated by separating and segregating the development, testing and live environments. This will prevent any problems in one environment affecting the others. Ensure that each environment has appropriate security measures in place.

Role based access control should be used here as well to restrict access to development and test environments to only authorized personnel. This Limits the risk of insider threats

or unauthorized access to sensitive development or testing data. Only developer and tester roles should be given access rights to the production, testing and live software environments.

Using strict access controls to restrict who can access which environment and what they can do on it. Only authorized software developers and other relevant staff should be allowed access. Use strong authentication and authorization mechanisms.

Secure the environments by disabling unnecessary services, applying security patches to the software and configuring firewalls and intrusion detection systems.

Utilize containers like Docker or virtual machines like to create isolated and consistent development and test environments. This minimizes the risk of one application affecting another, which will be crucial in the development and testing of the applications.

Kubernetes is an open source tool that automises the the deployment, scaling and management of containerized applications. Kubernetes has load balancing that can automatically distribute traffic to containers and manage the internal networking so that services can communicate with each other without intervention.

Kubernetes automatically monitors the health of containers and can restart or replace them if they fail, ensuring high availability and reliability for applications. This ensures that different application and project development components can be worked on smoothly without any interference or restriction.

Kubernetes also supports auto updates which can be used to ensure that applications are constantly updated to patch out software vulnerabilities and other bugs. There are also rolling updates that will update applications without downtime leading to a seamless and smooth experience and users can continue using applications as they are updating.

The development team will create a standardized environment that mirrors the production build closely. All developers and testers can work with the same setup regardless of their local systems.

Containers will run a single application or service, which means they only contain the necessary components to run that service. This limits the number of potential vulnerabilities compared to running multiple applications on a single operating system. The attack surface is reduced.

Threat 9 – Data Corruption Due to Software Bugs

Assumption

The complexity and crucial significance of seismic data processing software, such as Shake and Quake; in translating raw seismic data into usable insights for clients in high-stakes industries such as oil and gas exploration increases the risk of data corruption caused by software faults. These concerns may result from insufficient testing during development, especially when the software scales to handle increasing data quantities and real-time processing demands.

Example

A potential scenario could arise where a bug in the Shake and Quake software leads to incorrect interpretation of seismic signals, possibly misclassifying a seismic event or missing crucial data points. If such an error occurs during the processing phase, the generated report could provide misleading analysis to the client. In industries like oil and gas exploration, where accurate seismic reports are critical, clients might make poor drilling or exploration decisions based on corrupted data.

Impact

Corrupted data due to software bugs can lead to significant business and operational risks. Clients may lose trust in the accuracy of the company's services, which can harm the company's reputation and client relationships. Inaccurate data could also lead to

flawed decision-making, resulting in potential operational failures or safety issues in oil and gas exploration. If a threat like this ever occurs, it is safe to assume that the competitor will control the market, the competition software demand will increase, and our reputation will dissolve.

Mitigation

To avoid such risks, rigorous software testing, including unit, integration, and regression tests, should be performed to uncover defects before deployment. The strategy will include the following components:

Rigorous Testing Procedures:

Unit Testing: This will be conducted thoroughly for individual components to ensure each code functions correctly in isolation.

Integration Testing: to verify that different software components work together as intended, especially in data flow across applications.

Regression Testing: to ensure new code changes do not adversely affect existing functionality. This will involve automated testing frameworks such as **Selenium for web applications**.

Automated monitoring techniques should also be utilized to discover unexpected data patterns, which could signal a software issue. All apps' software flaws will be tracked and managed using a bug-tracking tool like **Bugzilla**. This allows for accountability and rapid maintenance by ensuring that problems are monitored systematically and prioritized for resolution.

A strong version control system (VCS), specifically the **Git application**, will be implemented to manage the development of all software applications. This will include:
Custom Features: Developing scripts to automate versioning and changelogs and integrate the VCS with Continuous Integration/Continuous Deployment (CI/CD) tools for automated testing and deployment.

Mechanisms for Monitoring and Rollback: Using tools for monitoring application performance and putting simple rollback protocols in place to return to stable versions when serious problems occur.

Threat 10 – Unauthorized Software Changes

Assumption

unauthorized software changes are likely due to human error, insufficient training, high workload demands, reliance on subcontractors, and weak protocols. Findings show 80-85% of errors in critical systems stem from human factors like fatigue, poor interfaces, and unsafe practices, increasing risks of unintentional or malicious modifications (*Alrawi & Pusatli, 2020*).

Example

If a developer or unauthorized personnel changes the code in **SensorDrill**, for example, altering how the software interprets sensor data, this could lead to inaccurate monitoring results. Changes that are not thoroughly reviewed or tested could cause sensor data reports to be false, such as underestimating pressure levels in a well. If such errors go unnoticed, they lead to equipment failure or safety hazards.

Impact

Unauthorized changes in SensorDrill or MeasureMe could lead to faulty data, equipment malfunctions, or environmental hazards. Clients who rely on these systems for real-time monitoring may make operational decisions based on incorrect data, leading to unfortunate results such as costly safety incidents or downtime. Additionally, if a security vulnerability is introduced, it could open the door for cyberattacks, potentially compromising sensitive operational data. In general, any impact of such an event will lead to the organization losing its reputation as a reliable company, losing its reputation

and, therefore, a huge part of its market share, thus driving it to a bad financial and legal situation.

Mitigation

The organization should implement strict access control mechanisms using role-based access control (**RBAC**) to limit who can change the SensorDrill, MeasureMe, and Shake and Quake software, ensuring that only authorized personnel with the proper credentials can modify the system. This includes implementing Multi-Factor Authentication (MFA) to enhance security during logins.

A thorough change management procedure should be set up, in which software change request is recorded and assessed for necessity and safety by a designated Change Advisory Board (CAB). Before being sent to production, all suggested modifications must pass rigorous testing in a staging environment and be approved.

To inspect any changes and identify unauthorized modifications early, software systems should be regularly audited and monitored. This involves maintaining strict surveillance of programs (especially upcoming projects) for irregularities that might point to illicit access or modifications and employing automated methods to detect unauthorized changes in the codebase. Integration of continuous monitoring solutions such as (**Tripwire**) a file monitoring tool that detects changes in the code files. is required to provide alerts for unusual activity and ensure that any differences are immediately fixed.

2.0 Organization physical threats

Threat 1- Intrusion:

Assumption

There are many external visitors, vendors and contractors that enter the company premises and any one of them could pose a threat to the physical security of the office premises.

60% of companies have encountered physical security breaches. Video surveillance has 30% market share in physical security. Access control is the most popular solution with 50% market share. (Pangarkar, 2024)

Example

There are intruder threats that can pose a physical security risk to the company. All visitors and contractors are required to sign in and obtain a visitor or contractor badge. Visitors are escorted in but are not escorted out. Contractors and vendors are neither escorted in nor escorted out.

This is a risk to physical security as visitors and contractors may come as malicious actors or intruders intending to roam the premises and intrude into areas or rooms they are not allowed to access. Since they will not be supervised or monitored after they sign in and gain access, they could be free to go anywhere within the premises.

Impact

Unchecked intruders can cause a lot of damage as they can access areas or rooms where they are not authorized to be, such as critical IT infrastructure like the server rooms. An intruder could tamper with or steal equipment, inject malware, or physically sabotage the systems.

Intruders may also access the employee cubicles and the offices of the management. This could allow them to access sensitive personal information about the company employees, which could lead to impersonation, identity theft, or financial damage.

Mitigation

To mitigate this threat, the physical security of the organization and its premises must be improved. Security guards and officers should be instructed to be more vigilant in monitoring and managing all visitors and contractors. They should ensure that once the visitors and contractors have completed their task and their visit is over, they are escorted or guided out of the premises.

Security access cards and locks should be used to secure critical areas such as the server room and staff rooms. All staff should be required to use a key card or other access token to gain access to these sensitive areas.

RFID keycards will be used to unlock the server rooms. They are more secure as they can be deactivated if they are lost. This prevents any intruders who gain access to keycards from accessing sensitive areas. A system can be setup to log keycard uses. This will record each time an RFID keycard is used to enter or exit a room. This can also be used to monitor and look out for any suspicious activities that may occur and to see who is accessing which room. The system can also be integrated with alarms that can trigger in case of any serious problems or breaches if someone tries to access the rooms after office hours.

CCTV cameras should be placed around the premises covering all important areas. The physical security team should constantly monitor them to keep track of all personnel within the building.

Dome CCTV cameras from Hikvision can be used indoors. These cameras have a 360-degree field of view, making them ideal for monitoring large spaces like the offices and hallways. Their shape also makes it difficult for anyone to see where they are pointing and

monitoring. This makes it difficult for any attackers to detect if they are under surveillance.

For the outdoor areas, bullet cameras from hikvision can be used. They have a longer viewing range than dome cameras, making them ideal for monitoring open outdoor spaces and ensuring clear footage across large distances. This will ensure that the office environments are closely monitored for any suspicious activities.

Threat 2 – Fire

Assumption

16% of oil and gas industry fatalities are due to fires. 22% of all workplace fires are electrical fires. (*Workplace Stats* | *MCR Safety*, n.d.)

There are many wiring rooms and server closets which could be fire hazards if not secured correctly. The nature of the organisation being in the oil and gas industry also introduces the risks of fires. This is why fire hazards are a critical physical threat.

Example

Fire is a physical threat that can cause extensive damage to the premises, staff, and critical IT infrastructure and equipment. Fire could be caused by air-conditioning system failures or malfunctions or electronic devices that could cause electrical faults, leading to sparks and electrical fires.

The wiring closets are a fire hazard, as well as the wires and equipment there can also be prone to fire if there is insufficient cooling and ventilation or any loose wires.

Impact

Fires could severely damage the premises, the employees, and the equipment such as servers and computers. This will cause significant damage to the organization as it would disrupt the operations and projects in development.

Damage to the servers can also cause loss of valuable customer and organizational data that will cause massive delays to production and can negatively impact the reputation of the company.

Mitigations

Mitigations against fire will include installing fire alarms and smoke detectors. There should be a reliable and robust fire detection and prevention system in place. Sprinklers should be deployed across the premises, especially in the critical server rooms and wiring closets.

There should be a fire evacuation plan in place to ensure all personnel can evacuate the premises safely in case of any fires to minimize the damage caused. All staff should be trained to follow the plan and must be aware of what actions to take in such events. Routine fire drills should be conducted to ensure that all staff continue to follow the evacuation plans and protocols in place correctly.

Fire extinguishers will be set up in common areas where fires could potentially break out. This will ensure that if the fire is small, someone can put it out. Employees will receive basic fire safety training to ensure they are aware of steps to take during fires.

Sprinklers will be installed in all rooms across the premises and especially in the critical server and wiring rooms. These rooms are critical for IT infrastructure and must be protected at all costs.

The fire extinguishers and sprinklers will be acquired from **Naffco**, a leading supplier of fire safety equipment.

Threat 3 - Power outage

Assumption

Power outages will disrupt all servers, network devices and computers as well as physical security mechanisms like CCTV surveillance and RFID locks.

Example

Power outages are another threat that can disturb and disrupt the operations of the organization since it relies heavily on technology and data processing.

Outages could be caused by weather conditions or power grid failures. These factors are outside the control of the organization, but it must be prepared to handle them regardless as they will have a heavy impact on the daily operations.

Impact

Power outages will affect all the critical IT infrastructure of the organization such as the servers, computers, routers and other electrical devices.

In the event of a power outage, the servers would lose power, causing immediate disruption to business operations. This will interrupt the data processing operations; it can lead to the loss or corruption of important client and organization data, can prevent employees from accessing the data required for their tasks.

It would also affect the network routers which will impact the communication and networks of the organization both internally and externally. This will also cause delays to operations and production.

The cooling and ventilation systems would shut down, leading to potential overheating of sensitive equipment. This could result in permanent damage to servers and network devices, leading to expensive repairs, extended downtime, and possible fires due to overheating or electrical faults.

These interruptions will damage the organization's reputation and its ability to complete and deliver its projects on time.

Mitigations

To mitigate against power outages, the organization should have reliable backup power supplies and generators in place. This will ensure that in the event of any power failures, the important electrical devices will remain functional, allowing the organization to continue their important operations and activities.

They can also use other power sources, such as solar panels, to continue operations in the event of power outages. There should also be backup servers and equipment available in case the data or devices are lost or damaged beyond repair during outages.

UPS generators from CyberPower will be installed to have reliable power supplies during power outages.

Threat 4 - Natural disasters

Assumption

The risk index for a tsunami is 7.2, drought is 6.5, flood is 5.3, tropical cyclone is 4.8 and earthquake is 0.2 (*Australia - Risk Index for Natural Disasters 2021 | Statista, 2024*)

This shows that the location of the organisation is prone to devastating natural disasters that can cause significant damage.

Example

Natural disasters are a threat that can cause significant and catastrophic damage to the organization and its operations. Disasters such as floods, earthquakes, or tsunamis can be devastating for the premises, IT infrastructure, and employees.

Impact

Disasters can cause severe structural damage to the buildings, roads, and other critical infrastructure of the organization's premises.

They can cause power outages, fires, or flooding, which will cause massive damage and destruction to the organization's assets, such as servers, computers, networks, and employees.

This can cause significant damage to the organization's operations, reputation, and projects and could even lead to a complete shutdown if they are not prepared to handle it appropriately.

Mitigation

The organization should have robust disaster recovery plans in place for situations like this. Due to the critical nature of their operations, the organization should invest in setting up backup sites with all the equipment and staff they require to continue their operations if irreversible and significant damage is caused.

Backup power generators and power supplies should also be available to deal with any power outages or failures caused by natural disasters.

They should have emergency evacuation protocols and plans in place and conduct regular drills with the staff to train them for such emergency situations to minimize the damage caused.

They should reinforce the foundation and structural integrity of their business premises to be capable of handling extreme weather conditions to an extent in order to minimize the damage caused.

Some natural disasters cannot be protected against and so they will become an acceptable risk. The only options for these situations would be to set up hot sites and move all production and operations to these hot sites to resume development.

Threat 5 – Unauthorized Physical Access to Server Room

Assumption

In our organization, unauthorized physical access to the server room is more likely due to operational gaps, such as reliance on cleaning staff and contractors without proper oversight and visitors not being escorted out after their initial entry. The habit of leaving the server room unsecured during operational hours heightens the danger of accidental or intentional breaches.

Example

An unauthorized individual could enter undetected if the server room door is accidentally left unlocked. This could include cleaning staff, contractors, or visitors who may have legitimate reasons for being in the vicinity but lack authorized access to the server room. Once inside, they could tamper with servers, install malicious devices (such as rogue USB drives), or even transfer sensitive data onto portable storage devices. These breaches could lead to data theft, unauthorized system changes, or severe equipment damage.

Impact

Unauthorized access to the server room poses serious risks to data confidentiality, integrity, availability, and the organization's reputation. Sensitive information kept within, such as seismic data, secret project files, and personnel information, may be compromised, stolen, or deleted. If this information is taken, unauthorized individuals or competitors may use it to harm the company's competitive advantage by disclosing trade secrets, project plans, or intellectual property. This loss of proprietary knowledge may harm the organization's market position, resulting in missing business opportunities and an inevitable drop in client trust.

Further, manipulated data, such as altered seismic readings or project documentation, could lead to flawed decisions. For example, a client may rely on compromised data to make critical drilling or exploration choices, potentially resulting in misinformed strategies, operational setbacks, or even accidents. This could lead to serious safety issues, financial losses, and reputational damage. Additionally, client or employee data

breaches could expose the organization to regulatory evaluation, legal penalties, and lawsuits, complicating financial and reputational consequences.

Mitigation

Electronic access controls like keycards such as (**HID Global iCLASS SE**) Reader system, an industry-standard access control solution, in the server room to ensure that only authorized people obtain access. This system provides strong security with encrypted RFID keycards, multi-factor authentication options, and integration with biometric equipment in high-security zones installed to prevent such incidents. Regular security checks should also ensure that the room is always locked. Additionally, personnel should be trained on security protocols to ensure they understand the risks of leaving the room unsecured.

Threat 6 – Hardware Failure

Assumption

Our organization's hardware failure is likely due to the intense workload placed on critical systems, such as servers and storage devices, during peak data processing periods. Eventually, all technology has a time limit, and an event of hardware failure of critical systems is low but possible (*Alsop, 2014; Arcserve, 2013; CXtec, 2024*).

Example

A server failure during peak data processing may cause a system crash, interrupting all ongoing activities. If a storage device fails, critical data may be lost or corrupted, disrupting workflow and delaying client reporting. Furthermore, if networking equipment fails, the entire processing system may be disconnected, limiting data access and incurring downtime until replacement or repairs can be arranged.

Impact

The impact of hardware failure could include data loss or corruption, compromising the reliability of seismic data. This would jeopardize client deliverables and disrupt trust in the company's services. Additionally, prolonged downtime would delay data processing tasks, increasing operational costs and reducing efficiency. If the issue persists, the company could face financial penalties or client dissatisfaction due to missed deadlines.

Mitigation

Scheduled Maintenance and Real-Time Monitoring Regular inspection and upkeep of hardware components can identify and prevent potential issues before they lead to failure. Products like (**Nagios**) provide real-time monitoring and alerting, helping detect early signs of hardware stress or degradation.

Establishing redundancy in hardware systems (e.g., RAID 6 configurations for storage or load-balanced server clusters) can prevent a single hardware failure from causing system-wide interruptions. RAID 6 is especially useful in this scenario because it improves fault tolerance by allowing the system to continue functioning even if up to two drives fail simultaneously. This industry-standard configuration ensures high data integrity and read efficiency, critical for intensive seismic data processing while maintaining storage capacity and redundancy. Furthermore, load-balanced server clusters can disperse processing workloads uniformly, preventing any one server from becoming a point of failure.

Threat 7 - Temperature rise in critical areas

Assumption

A temperature rise in critical areas is based on the assumption of heavy reliance on continuous data processing operations, combined with aging or inadequately maintained cooling systems. The absence of advanced environmental monitoring tools and redundant cooling mechanisms further exacerbates the risk, especially during peak operational loads or unforeseen system malfunctions.

Example

If the cooling system in the data processing room malfunctions and the temperature increases beyond acceptable levels, servers and storage devices could overheat. This may lead to data processing delays, hardware malfunctions, or complete system failure, putting sensitive client seismic data at risk.

Impact

The primary impact of a temperature rise includes hardware damage, resulting in data corruption or loss, particularly if storage devices and processing units fail. Prolonged exposure to high temperatures can shorten the lifespan of equipment, leading to frequent breakdowns. A temperature-induced system crash could delay critical data processing tasks, affect client deliverables, and result in financial losses. Continuous failures may lead to expensive hardware replacements and loss of client trust.

Mitigation

To mitigate the threat of rising temperatures in critical areas:

- **Water Cooling System Integration:** Installing a water-cooled system, especially for high-density server racks, can efficiently manage temperature in environments with intensive data processing demands. Systems like (**CoolIT Systems**).
- **Environmental Monitoring Systems:** Installing a continuous monitoring system for temperature and humidity levels. Systems like the (**APC NetBotz**) can alert personnel automatically when temperatures deviate from safe thresholds.
- **Routine Maintenance of Cooling Systems:** Schedule regular maintenance for air conditioning units and cooling infrastructure to ensure they operate efficiently and prevent overheating.
- **Automated Shutdown Protocols:** Configure automated shutdown protocols to the servers and suspend non-essential processes or initiate safe hardware shutdowns if temperatures reach critical levels, protecting equipment from damage.

Threat 8 – Unauthorized Access via Wireless Networks

Assumption

The widespread use of Wi-Fi for internal operations, including Shake and Quake data processing, increases exposure to unauthorized access by attackers exploiting weak wireless security.

Example

Wireless networks in the building provide convenient access for staff across multiple floors. However, if wireless access is not secure, it could allow unauthorized individuals to access the network, which can, in turn, compromise sensitive data within critical departments, like Data Processing and R&D. This can also cause compliance risks, as unauthorized access to sensitive data could lead to legal liabilities under data protection laws. An attacker in the building's vicinity uses a high-gain antenna to connect to the company's wireless network. Gaining unauthorized access to the network, the attacker is able to intercept sensitive communications, such as client seismic data from Shake and Quake, or ongoing R&D developments for SensorDrill upgrades.

Impact

Unauthorized network access could expose confidential client data and proprietary information, creating vulnerabilities that may lead to data breaches, intellectual property theft, or network disruptions. This exposure risks legal consequences, reputational damage, and even the client losing trust in the company.

Mitigation

Secure Wireless Networks: Use **Cisco Meraki MR56** wireless access points to segment sensitive networks, creating isolated wireless channels for critical departments like R&D and Data Processing.

Wireless Intrusion Prevention System (WIPS): Deploy **Aruba ClearPass** for real-time monitoring and control of wireless traffic. Aruba's WIPS capabilities detect and prevent unauthorized access attempts, issuing alerts if unknown devices attempt to connect.

Regular Security Audits: Conduct regular wireless security audits with **EkaHau Pro** to identify vulnerabilities in the wireless infrastructure and adjust signal strength or channel configurations as needed.

3.0 Organization People Related threats

Threat 1 – Social engineering

Assumption

98% of cyber attacks utilize social engineering. The average organisation faces over 700 social engineering attacks annually. The average costs of social engineering attacks are \$130,000. (*What Are Social Engineering Attacks? A Detailed Explanation* | Splunk, n.d.)

This makes social engineering very dangerous as it can lead to employees getting compromised and being used against the organisation. This can cause serious damage to the critical and sensitive data and devices of the organisation.

Example

The staff of the organization could be vulnerable to social engineering. The visitors, contractors and outsourced staff could potentially come as malicious actors intending to manipulate the staff into providing sensitive information about the organization and its operations.

Since the visitors and contractors are not escorted out when they are finished, they can freely walk around the premises and interact with the staff and equipment. This will provide social engineering opportunities for them as they can engage in social manipulation to gain the trust of staff members to get access to key information.

Impact

If staff members are manipulated or tricked into giving away sensitive information and details of the organization to attackers, it can cause significant problems and disrupt the operations. Attackers could cause damage to the equipment like the servers and other IT devices. They could gain access cards into highly privileged areas and offices which contain highly sensitive information and documents.

Mitigation

Staff members should be trained to avoid common social engineering attacks and schemes. They should be informed of steps to take if they suspect a staff member or visitor may be a potential attacker. Thorough background checks of all incoming visitors, contractors and temporary staff members should be done to ensure that they are legitimate and genuine. They should also be escorted outside once they are finished to ensure they leave the premises.

Security education and awareness (SETA) programs will be carried out regularly to ensure that employees remain up to date on the latest

Background checks will be done by **Checkr**, a trusted third party background screening company that will check for important details like criminal records for all visitors and contractors.

Threat 2 – Phishing

Assumption

All employees use email and the internet which leaves them prone to phishing attacks. Phishing attacks are also increasingly widespread and common.

1.2% of all emails are malicious which equals to 3.4 billion phishing emails daily. Every year, 83% of all organisations face phishing attacks. (Saxena, 2024)

Example

Staff could be prone to phishing attacks carried out by attackers. These can be in the form of fraudulent emails that contain malicious links that can steal sensitive information or install malware on the computer if clicked.

Impact

Phishing attacks can be very damaging as losing sensitive information or getting infected with malware can cause significant damage to the organisation's data, staff, clients and operations. They can compromise the devices of the organization as well as the personal and sensitive details of employees and clients.

Mitigation

Employee training and workshops on phishing attacks should be conducted to inform them of the dangers of phishing attacks and how to avoid them. Employee emails should have filters set up to identify and delete incoming spam and phishing messages.

The phishing platform **cofense phishme** will be utilized to teach employees the dangers of phishing and how to counter it.

Spam filters will be set up and enabled on all email clients used in the organisation. Emails that are flagged as potential spam or phishing attempts can be automatically sent to a spam or junk folder. This will reduce the chances of employees engaging with suspicious or harmful links that could compromise their data, devices and applications. The **Cisco Firepower 1120 Series** installed will also be instrumental in detecting and preventing phishing. They can block known malicious Ips and the IPS mode can be utilised in case of any phishing links getting past the firewall to ensure they are immediately deleted before someone clicks them.

Threat 3 – Insider attacks

Assumption

From 2019 to 2024, organizations from across various sectors that have reported insider attacks have increased from 66% to 76%. (Enterprise IT World, 2024)

Insider attacks are increasingly common, and since the organization is in the oil and gas industry, the data it deals with is very sensitive and crucial. Insider attacks can disrupt operations and lead to data breaches, which will cause significant financial, reputational, and legal damage.

Example

Insider attacks from the organisation's own employees can be significantly damaging. Employees would already have access to most of the devices and IT infrastructure like the server. They would be aware of the layout and organizational structure of the company. They can exploit their insider knowledge to attack the organization discreetly by stealing, deleting or tampering with sensitive data and damaging or sabotaging.

Impact

Insider attacks can be significant. They could lead to the theft of proprietary software or sensitive data about the organisation's seismic operations. These could be sold or leaked to competitors or the public which would cause the company to suffer significant competitive disadvantages.

Insiders tampering with the company software or hardware like the servers will also cause disruptions to the company operations. This downtime will delay the projects and will be costly to the organization. These attacks could also lead to confidential data breaches which would expose or leak staff and client information. This will cause a massive reputational loss for the organization and lead to legal issues about sensitive data breaches.

Mitigation

The principles of least privilege should be applied throughout the organisation.

Employees should only be given the least amount of data and device privileges required to do their tasks. If they require higher privileges then these should only be given temporarily under supervision and then taken after the task is done. This will prevent insiders from abusing their privileges to attack the organization.

Role-based access control will be implemented to ensure the least privilege for all employees. They will only get the access rights associated to their roles. This will ensure that employees who are not meant to access server rooms or the source code of applications do not access it.

RFID access cards for the server and wiring rooms should only be provided to relevant employees who need to access them. The use of RFID cards should be regulated and monitored to ensure no unauthorized employees or any external visitors are entering these rooms.

Threat 4 – Poor security practices

Assumption

88% of cyber attacks are caused by employee negligence and following poor security practices and procedures. (Laventure, 2021)

Untrained employees will not follow all of the correct security steps to secure themselves, their accounts and the organisation's devices and data.

Example

Poor security practices or negligent behaviour from employees can make the organisation more prone to attacks. Weak passwords that are easily guessable will increase the risks of employee accounts getting compromised. Employees reusing the same password for all their accounts is another security risk as one account getting compromised could lead to all their accounts getting compromised by attackers. This creates a single point of failure, making it easier for attackers to access critical systems and accounts.

If employees are not aware of the recommended security practices, they will be more prone to phishing, social engineering and account hijacking attacks.

Employees may also be negligent when handling the IT devices or organisation and client data if they are not well trained or aware of the security policies in place. This could lead

to mishandling of confidential data and the IT infrastructure which can cause operational disruptions and data breaches.

Impact

Poor security practices will make the organisation vulnerable to many kinds of attacks. Employees could fall for phishing or account hijacking attacks which will lead to attackers stealing their personal and organisation sensitive data. This could then be used by attackers to impersonate employees and attack the organisation which will cause further damage.

Mismanagement and mishandling of organizational data and devices can negatively impact the daily activities and operations of the company which will cause delays in their projects. Data breaches will be likelier to occur if employees don't handle it with the correct security policies and guidelines.

Mitigation

Employees should be trained through workshops and awareness programs to inform them of the best security practices and behaviours. The organisation should update its security policies to ensure that employees set complex passwords that would be hard to crack. They should ensure that employees use a different password for each account and that employees regularly change their passwords to keep their accounts secure.

Employees should be aware of the steps to take when they face phishing or social engineering attacks so they do not fall for them and compromise their credentials.

Regular security auditing and testing should be done to ensure that employees are complying with the security policies, procedures and practices that have been set by the organisation. This auditing will be done internally as well as externally through

Threat 5 – Password Sharing

Assumption

Employees may share their passwords due to convenience or lack of awareness about the risks. Password-sharing incidents are common, with **81% of hacking-related**

breaches involving compromised credentials. Unsecured password-sharing practices can lead to unauthorized access and data breaches. (Verizon Data Breach Investigations Report, 2023)

Example

Password sharing can create a big risk to the organization, especially when they have proprietary software such as SensorDrill and Shake and Quake. By password sharing, data breaches can take place due to unauthorized access and there can be potential compliance risks and legal implications of such a breach, given the high-value nature of the intellectual property. An example of this could be that an employee in the R&D department shares their login details with a colleague for some reason. This colleague, due to not having awareness, leaves the login details in the open or somewhere visible, such as an email. An attacker who gains access to this information could then exploit these credentials to access projects like the real-time remote monitoring upgrade for SensorDrill, or if an employee shares credentials with a colleague in the Data Processing or Seismic Exploration departments, this can have a major risk as it opens a way for unauthorized access to sensitive seismic data or project files.

Impact

Password sharing creates significant security risks, such as unauthorized changes to sensitive project files, potential loss of intellectual property, and a breach of client data, causing damage to the company's reputation, loss of competitive advantage, and possibly even loss of clients. An attacker who gains access to one employee's account can access sensitive information and perform unauthorized actions such as compromising the system, which can cause disruptions in day-to-day operations.

Mitigation

Password Policy Enforcement: Deploy **LastPass Enterprise** for centralized password management, enabling staff to securely share login credentials when necessary while keeping records of access.

Multi-Factor Authentication (MFA): Implement **Okta Identity Cloud** across all critical systems, especially for R&D and data processing access points, to ensure that even if passwords are shared there is still another factor of authentication that is needed.

Awareness Training: Conduct regular training sessions by hiring training experts to educate staff on secure credential practices and the consequences of sharing passwords with one another.

Threat 6 – Untrained Part-time Staff

Assumption

Temporary staff supporting IT and customer service operations for MeasureMe and SensorDrill often lack the training to identify phishing emails or adhere to security policies, increasing the risk of accidental data breaches.

Studies show that 60% of organizations experience data breaches due to human error, and temporary staff are often the weakest link in security. (Ponemon Institute, 2023)

Example

The company relies on temporary or contract-based staff for certain tasks or during peak periods. This could create risk associated with untrained personnel. These staff members may unintentionally bypass security protocols, especially if they handle customer inquiries or have indirect access to sensitive data if they do not know the company's security policies and best practices. Due to this, any mishandling of sensitive information by untrained staff could lead to compliance issues, particularly regarding data protection laws. A part-time employee assigned to assist with technical support for MeasureMe unknowingly opens a phishing email, granting unauthorized access to the system. This happens because the employee lacks the training to recognize such threats. They unknowingly expose the company to potential data breaches that could lead to unauthorized access to client data.

Impact

Untrained part-time staff could unintentionally compromise systems, leading to data breaches or unauthorized access. This could have financial consequences and harm the company's reputation, especially if sensitive client information related to seismic projects is leaked.

Mitigation

Mandatory Security Orientation: Use **SANS Security Awareness Training** to provide essential cybersecurity training to all temporary and contract staff before they are given access to company systems. undergo a mandatory security orientation that covers the company's information security policies, including how to handle sensitive data. Temporary staff should have limited access to systems and data, and their activities should be closely monitored during their tenure. **Access Control and Monitoring:** Implement **Microsoft Azure Active Directory (AD)** for temporary staff, assigning limited, role-based access to systems.

Threat 7 – Lack of Proper Offboarding Procedures

Assumption

Employees who leave the company often retain access credentials to critical systems, creating opportunities for unauthorized access to proprietary software and client data.

Example

Proper offboarding is essential to maintaining the security of intellectual property, particularly for employees involved in sensitive projects such as Shake and Quake. Former employees, such as a Data Processing employee with leftover access credentials, use their old account to download proprietary seismic data processing algorithms, which they then sell to a competitor. Without immediate account deactivation upon termination, sensitive information could remain exposed. Any breach in this area could lead to substantial legal and reputational ramifications, particularly if a former employee accesses and discloses proprietary data after departure.

Impact

Retained access by former employees presents significant risks, potentially resulting in intellectual property theft, data breaches, or sabotage of company projects. Unauthorized access to proprietary data or confidential project details could lead to financial losses and company's bad reputation.

Mitigation

Automated Offboarding Procedures: Use **Okta** for identity and access management to automate offboarding, ensuring that all access rights are promptly removed upon termination.

Exit Interviews and Final Audits: Conduct exit interviews, focusing on assessing potential risks for critical project employees. Use **SolarWinds Access Rights Manager** for a final audit to confirm all system accesses have been deactivated.

Device Collection and Secure Wiping: Utilize **Blancco Drive Eraser** to securely wipe devices previously used by employees who are leaving the company to prevent residual data from being accessed.

Threat 8 – Social Media Threats

Assumption

In our organization, employees' pervasive use of social media and its integration into daily operations increases the risk of external threats. Attackers could exploit social media platforms to gather publicly available information about our company, such as personnel profiles, job postings, or company events. This data could be weaponized to craft sophisticated Phishing attacks, which have risen by 130.5% since 2017, and many breaches occur due to user errors, accounting for 94% of incidents. Attackers exploit these platforms to gather sensitive organizational or personal information, launch sophisticated social engineering attacks, or impersonate employees to gain unauthorized access (*Khaled, 2024*).

Example

An attacker could use an employee's social media activity to gain insights into their employment, responsibilities, or personal preferences, allowing for highly targeted phishing attacks. Attackers that impersonate an employee or their company could ask for sensitive information, gain access to credentials, or spread malware disguised as updates or rules. Furthermore, seemingly innocent tweets on project timetables, technology adoption, or organizational changes may offer attackers the background they require to craft convincing malicious messages, resulting in data breaches, ransomware attacks, or substantial operational disruption.

Impact

Social media threats can potentially undermine the organization's security posture by providing attackers with an entry point into critical systems. Phishing campaigns initiated via social media can compromise employee credentials, allowing unauthorized access to sensitive data and systems. This could lead to data breaches, operational disruptions, and reputational damage. Fake company profiles or impersonations could also disrupt client and partner trust, impacting business relationships and financial stability.

Mitigation

- **Social Media Policy:** Create a clear policy restricting sensitive information sharing, such as project specifics and operational changes.
- **Awareness and Training:** Regularly educate staff about the risks of social media, focusing on phishing, social engineering, and secure information handling.
- **Access Control:** Limit social media posting to a specific team and educate employees not to share company information on personal accounts.

Threat 9 – Unintentional Data Leakage

Assumption

Unintentional data leakage occurs due to human error, such as employees accidentally sharing sensitive information via email or using unauthorized personal cloud storage for convenience. These errors are prevalent, with over 66% of business users reportedly sending sensitive information mistakenly **Ahmed, A. E. (2018)**.

Example

A team member working on an important data project unintentionally attaches a private report to an email intended for external partners, revealing sensitive information. Alternatively, an employee working on cross-departmental projects may use personal cloud storage for quick access, putting sensitive data at risk if it is not secure or approved by company policy.

Impact

Unintentional data leakage can have serious consequences, including disclosing trade secrets, competitive information, or client-specific data. Such breaches may result in financial loss, noncompliance with regulatory standards, reputational injury, and possible legal ramifications if client agreements are broken. For example, competitors could gain access to private operational processes or critical R&D data, compromising market advantage.

Mitigation

Data Loss Prevention (DLP) with **McAfee Total Protection** for DLP offers comprehensive control over sensitive data within the organization, monitoring and protecting it across endpoints, networks, and the cloud. It prevents accidental data leakage by enforcing policies on data transfers and providing real-time alerts for potential risks.

Email Verification with **Barracuda Email Security Gateway** adds an essential layer of email security, reducing the risk of data leaks through email errors or unauthorized

recipients. This tool inspects outgoing emails to ensure they comply with corporate data policies, allowing for the safe sharing of sensitive information with clients and partners.

Threat 10 – Incompetent Staff or Team

Assumption

The assumption stems from the organization's reliance on complex IT systems, insufficient training programs, and difficulty recruiting experienced workers. Along with loose hiring procedures and relying on contractors.

Example

An untrained IT staff member may fail to correctly configure firewalls, leaving crucial systems across many service offerings vulnerable to external threats. A lack of understanding about correct coding practices can cause bugs and vulnerabilities. Furthermore, employees who lack cybersecurity awareness may disregard sensitive data, reuse weak passwords, or fall victim to phishing attacks.

Impact

Incompetent staff can lead to data leaks, faulty system configurations, operational disruptions, and increased vulnerability to attacks. This can lead to data breaches, financial losses, downtime, and reputational damage. Furthermore, mismanaged IT infrastructure might result in compliance issues and legal consequences.

Mitigation

- Establishing **extensive training programs** that include critical cybersecurity procedures, suitable system setups, and data handling protocols specific to each service area inside the firm. This training should be mandatory for all staff and updated regularly to reflect evolving dangers.
- Implement **strict hiring processes** to guarantee that qualified and competent employees are hired, including thorough background checks and technical competence evaluations relevant to their responsibilities.

- **Developing and maintaining detailed documentation** describing processes for managing sensitive data and configuring critical systems.
Employees will be encouraged to follow best practices if standards are easily accessible, reducing the risk of errors.

4.0 Organization Policies and Procedures Threats

Threat 1 - Weak Password policies

Assumption

Over 80% of breaches are caused by weak or stolen passwords. 96% of common passwords can be cracked in less than a second. 80% of web application attacks are due to stolen passwords. (Stouffer, 2024)

The organisation has a password policy but it does not regularly enforce it. This can result in employees continuing to use the same old passwords which creates significant security risks for their accounts. If these accounts get compromised, attackers will gain access to sensitive organisation information.

Example

The company has weak password policies. They only encourage employees to change their passwords regularly and to not share it but this is not enforced. Due to this, employees may forget to change passwords and may keep using the same password throughout.

They may also use the same password for multiple accounts. If the password gets compromised for one, then all of the employee's accounts can get compromised.

Impact

Attackers can crack weak employee password and this will give them access to the company's information systems and other systems that store and process sensitive company, employee and client data.

Mitigation

The password policies will be enforced throughout the company so it becomes mandatory for employees to regularly change their passwords. The information systems and other applications the employees use should ask the employees to change their passwords to continue logging in after regular intervals of 6 months or whatever the company requires.

These policies should also ensure that if employees have multiple account related to the company, all these accounts should have different passwords to prevent attackers from gaining easier access to the systems.

Employees not updating their passwords will be locked out of their accounts until they change their passwords according to the password security standards and policies set up.

LastPass Enterprise will be set up for all employees to help them manage all their different secure passwords. This will encourage them to set up various different strong passwords for all their accounts as they would not need to memorise them.

Threat 2 – Physical security policies

Assumption

The open server rooms and wiring closets contain important servers and networking devices. There are many external visitors, vendors and contractors that enter the company premises and any one of them could pose a threat to the physical security of the office premises.

60% of companies have encountered physical security breaches. Video surveillance has 30% market share in physical security. Access control is the most popular solution with 50% market share. (Pangarkar, 2024)

Example

There are no physical security policies currently implemented by the company to properly secure their server rooms, offices and other sensitive areas.

The server rooms remain open until closing time and the wiring closets are always unlocked.

Impact

Attackers could exploit the open rooms and access sensitive areas of the company like the server room and wiring closets which are unlocked. They could tamper with the equipment or gain access to it which would disrupt and cause damage to the information systems.

Mitigation

Physical security policies and procedures should be developed and implemented to protect the crucial areas and equipment of the organization. Server rooms should always be locked using a key card or other security system.

Employees should present their keycards or other security tokens each time they want to access the server room to unlock it. This will prevent unauthorized intruders or attackers from gaining entry to the server rooms. Wiring closets should also be locked using the same mechanism to ensure only authorized personnel are allowed access.

Role based access control is applied to only give permissions to employees based on their roles. This creates separation of duties

Following the principle of least privilege, the **RFID** security keycards and tokens should only be issued to the employees who would require access to the server room and wiring

closets. They are not given to employees who have no responsibilities requiring higher access levels or privileges.

Threat 3 – Visitor policies

Assumption

There are many external visitors, vendors and contractors that enter the company premises and any one of them could pose a threat to the physical security of the office premises.

60% of companies have encountered physical security breaches. Video surveillance has 30% market share in physical security. Access control is the most popular solution with 50% market share. (Pangarkar, 2024)

Example

There are no policies or procedures for visitors and contractors while they are on the premises. They are not monitored or supervised when they enter or exit. This allows them to roam the premises and go wherever they would want.

Threat

Not monitoring visitors and contractors means that they essentially have unrestricted access to the premises. They can go into any area or room they would want without anyone stopping them. Attackers can break into information systems and steal information due to their free movement throughout the organisation. They can damage or sabotage the critical IT infrastructure of the organisation as the server rooms and wiring closets are unlocked.

Mitigation

Visitor policies and procedures should be put in place. Visitors and contractors should always be monitored using security guards and CCTV cameras. Any external visitors

should be escorted in and escorted outside when they are done. Background checks should be done before visitors or contractors are allowed inside the premises.

Employees should be trained on security procedures if they encounter any outsiders engaging in any suspicious activities in the organisations.

The **Hikvision dome cameras** will be used indoors and **bulletproof cameras** will be used outdoors to monitor all personnel, devices and activities inside and outside the premises.

Checkr, a background screening service will be done on all incoming visitors and contractors to ensure only reliable and genuine third parties are entering the company office.

External parties should only be granted the minimum amount of access they require. Their access should be regulated by only providing temporary **RFID** keycards if required to access any secure rooms. These should then be disabled to taken back from them once their tasks are done and before they have left the premises.

Threat 4 – Software policies

Assumption

Outdated software introduces many vulnerabilities. Unpatched known vulnerabilities in outdated software cause 60% of data breaches. (Önen, 2024) .

Since auto updates are disabled, there is a very high chance there will be many different softwares on the company devices that are outdated.

Example

Currently the organization has disabled auto updating of the operating system of all client PCs. There are delays in applying software patches due to concerns over compatibility with the existing software applications.

Impact

While compatibility issues should be considered, delaying OS updates can lead to serious vulnerabilities in the client PCs which could be exploited by attackers. This could lead to attackers exploiting the client PCs and gaining access through viruses, backdoors or remote code executions.

Gaining access to the client PCs will compromise the information system infrastructure of the organisation as attackers can access all the employee and organisational data. They can then use the client PCs to attack the other devices like the servers.

Mitigation

The software policies and procedures should be revised to make software updates more frequent. If compatibility will be a problem, the software patches should be applied to test systems first to ensure they will run smoothly and then be applied to the main client PCs as soon as possible.

Updating the operating system on time will ensure that any vulnerabilities or exploits that exist will be patched out quickly so that attackers will find it more difficult to attack the organisation's devices.

Acunetix vulnerability scanner will be used to regularly check for any vulnerabilities and exploits in the software.

Software will be regularly audited using this scanner and will be updated as soon as possible with the latest security patches.

Threat 5 – Lack of Data Backup and Recovery Procedures

Assumption

Backup failures can be common if they aren't set up correctly. 26% of backup and recovery fail. 60% of backups are incomplete and 50% of restores fail. (*The Failure of Backups and Restores: A Growing Concern in Data Management*, n.d.)

This is why incorrectly setup backup procedures are a threat that can cause significant damage to the organisation if their backup plans do not succeed.

Example

The firm keeps critical customer data on tapes stored on open racks in the data processing area without access controls or security measures. There are no formal protocols to ensure that these backups are handled securely, encrypted, and stored offsite. Furthermore, no rules exist for how frequently backups should be conducted or reviewed for data integrity.

Impact

Even though the data tapes are stored in a locked room, relying solely on physical tapes for critical client data in a single location still exposes the organization to significant risk. In a natural disaster like a fire or earthquake, the original data and backups could be destroyed simultaneously, as a locked room does not mitigate the impact of environmental threats. Furthermore, physical tapes are vulnerable to wear and data degradation over time, increasing the risk of data loss without regular integrity checks. Additionally, the lack of encryption for the stored tapes means that the sensitive data could be compromised if they are accessed or stolen. There is also the possibility of insider threats; someone with malicious intentions, such as an unhappy employee, might gain access to the room and sabotage the primary servers and the backup tapes. In such a scenario, a single breach could cripple the organization's data infrastructure, resulting in the loss of both original and backup data.

Mitigation

The organization must develop an effective data backup and recovery policy. This strategy should include storing onsite and offsite backups in a secure, encrypted format to protect sensitive information from unauthorized access. A cloud solution like **Amazon Web Services (AWS)** can provide a reliable offsite backup option that enables secure and scalable data storage. The data processing room should have closed, tamper-proof storage cabinets for physical tapes, and backups should be performed regularly, with integrity checks to ensure data quality. In addition, a formal Disaster Recovery Plan (DRP) should be established to specify the procedures for recovering data in the case of a loss or failure. The DRP should detail steps for data retrieval, roles and responsibilities, and communication protocols during an incident.

Threat 6 – Absence of Incident Response Plan

Assumption

This assumption arises from the fact that a survey of over 3,600 IT workers worldwide found that 77% did not have a cybersecurity incident response strategy, leaving them unable to deal with possible events properly (*Mutalib, Zainol, and Halip 2021*).

Example

The organization has no clearly defined Incident Response Plan (IRP) for responding to data breaches, cyberattacks, or internal security lapses. For example, what can occur in case of a Distributed Denial of Service (DDoS) attack on the organization's main servers, a lack of a clear plan will cause uncertainty among personnel about who to alert and what immediate steps to take. This lack of clarity will result in a delayed reaction, rendering the system overloaded and inaccessible to users for an extended period of time. Without an IRP, personnel may be unsure of the protection, reporting, and communication processes during security incidents.

Impact

Without a structured IRP, an organization faces a slow and unorganized response to security breaches or system failures. Without an IRP, security breaches may go undetected, prolonging exposure times and allowing attackers to compromise more data. This delay could result in extended system outage, considerable financial losses, reputational damage, and potential legal ramifications if critical client or staff data is lost. The resulting operational disruptions may have a negative impact on overall productivity and trust among clients, making it more difficult for an organization to recover after the disaster.

Mitigation

To counter this threat, a formal Incident Response Plan (IRP) should be developed that specifies an organized process for dealing with all sorts of security incidents, including cyberattacks, data breaches, and system failures. The IRP should include stages such as detection, containment, eradication, and recovery, as well as an incident response team's duties and responsibilities. Regular training sessions and simulated incident exercises for the staff will be required to ensure that everyone understands their responsibilities in the response process. Testing the IRP's performance through frequent assessments and real-time simulations can assist the organization in maintaining a high level of preparedness and reducing the impact of potential security crises.

Threat 7- Lack of System Monitoring and Security Audits procedures

Assumption

The organization's lack of system monitoring and frequent security audits could be explained by minimal investment in cybersecurity infrastructure and tools, insufficient staff experience or prioritizing of security oversight.

Example

The organization does not monitor system logs or network traffic for suspicious activity or undertake regular security assessments. This leads to a loss of the possibility of detecting unauthorized access attempts or system vulnerabilities. Without audits, it is difficult to assure compliance with security policies, and any vulnerabilities in the infrastructure may go undiscovered.

Impact

The lack of constant monitoring and frequent audits exposes the organization to several problems. Undetected intrusions may occur, allowing attackers to operate within the network undetected, resulting in long-term damage. Vulnerabilities such as unpatched systems or misconfigurations may go undetected, leaving the infrastructure vulnerable to attack. Without proper log management, tracing incidents or determining the source of security breaches is difficult, limiting response efforts. Furthermore, if security measures such as changing passwords and access controls are not frequently checked, employees may disregard them, increasing the risk of insider threats or unintentional breaches.

Mitigation

This procedure can be achieved by setting up a centralized monitoring system with a Security Information and Event Management (SIEM) solution like **Splunk**. This technology may detect anomalies in real-time and generate notifications for suspicious activity, improving the organization's threat detection capabilities. Regular security audits should be performed to evaluate access controls, patch management, and system vulnerabilities. Establishing a log retention policy that includes regular audits would result in a thorough audit trail for incident analysis, hence increasing responsibility.

furthermore, implementing an Intrusion Detection and Prevention System (IDS/IPS) like **Snort** will actively monitor network traffic, analyze it in real-time, and prevent threats by identifying suspicious activity, thus enhancing the organization's level of security.

Threat 8 – Lack of Employee Security Training

Assumption

This assumption can be due to reliance on automated systems. The organization depends too heavily on technical safeguards while ignoring personnel training. Uncertain responsibilities and compliance requirements further diminish security awareness. Employees who do not receive organized training are nevertheless unprepared to deal with risks, increasing their vulnerability to phishing/social engineering, data negligence, and delayed breach reactions.

Example

The company has no security training program to educate employees on recognizing and preventing security threats like phishing, social engineering, and weak passwords. This lack of education increases the likelihood that employees may unknowingly compromise the organization's security.

Impact

Employees who do not receive proper training are more vulnerable to phishing attempts and other social engineering tactics, which can result in the unintended exposure of sensitive data and systems to malicious actors. This lack of knowledge can have severe consequences, including unauthorized access to confidential information, major financial losses, and potential data breaches that destroy client trust and ruin the organization's reputation. Furthermore, employees may mishandle sensitive information by sending passwords or valuable customer data across unsecured channels, increasing the risk of insider threats.

In addition, without proper training on established security procedures like the Incident Response Plan (IRP) and Disaster Recovery Plan (DRP), employees may struggle to respond effectively during security incidents. This knowledge gap can create confusion and slow the organization's ability to act rapidly, increasing the impact of breaches and extending recovery times.

Mitigation

To address this threat, the organization should establish a thorough Security Education, Training, and Awareness (SETA) program. This program should teach employees to recognize phishing attempts, handle sensitive information securely, and follow strong password policies. Additionally, training should emphasize complying with the organization's established security processes and policies, such as the Incident Response Plan (IRP) and Disaster Recovery Plan (DRP). Regular training sessions and continuing awareness initiatives (such as posters and newsletters) will help to reinforce security measures. Simulations of different kinds of threats should ensure that staff can implement what they've learned, and the training program should be updated regularly to reflect emerging threats.

Threat 9 – Inconsistent Data Classification and Handling Procedures

Assumption

The lack of standardized protocols for classifying sensitive data like seismic reports and proprietary algorithms leads to mishandling and potential exposure.

Example

The company handles various types of sensitive data, including client seismic data processed through **Shake and Quake**, proprietary information on **SensorDrill** and **MeasureMe**, and internal financial data. However, there is no clear data classification system in place that can be used to classify data accordingly (e.g., “Confidential,” “Internal Use Only,” “Public”). Due to not having standardized data classification and handling procedures, this could lead to the mishandling of sensitive seismic data or intellectual property, potentially exposing the company to risks. Inadequate data handling could lead to compliance issues, legal liabilities, and a breach of confidentiality agreements with clients. Without a formal classification protocol, they may not be able to differentiate between sensitive data and less critical information and store them together or transfer them using unsecured methods. This lack of structured handling increases the likelihood of accidental exposure, unauthorized access, or data leaks.

Impact

Without standardized data classification and handling procedures, sensitive data could be mishandled, leading to unauthorized access, data breaches, or leaks of proprietary information. This poses significant legal and financial risks, especially if confidential client data were inadvertently exposed or misused. For example, improper storage of seismic data could lead to a breach of client confidentiality, impacting trust and potentially leading to contract losses. Misclassified data could also complicate compliance with data protection laws, increasing exposure to legal consequences and damaging the company's competitive edge.

Mitigation

Data Classification Policy Implementation: Establish a data classification framework using Microsoft Information Protection (MIP). MIP allows for labeling and categorizing data as “Confidential,” “Internal Use,” and “Public,” making it easier to set specific handling procedures for each type. This structured approach ensures that seismic data, proprietary software, and financial records are handled appropriately, safeguarding sensitive information.

Employee Training on Data Handling: Conduct comprehensive data handling training using **KnowBe4 Security Awareness** Training to educate employees on classifying and managing data in line with the established framework. This training should emphasize handling procedures for seismic data, internal financials, and proprietary software, ensuring staff are aware of classification protocols reducing the risk of mishandling confidential information.

Access Controls and Alignment with Data Classification: Implement **Microsoft Azure Active Directory (AD)** for role-based access control (RBAC) aligned with the data classification framework. By assigning permissions based on data sensitivity, only authorized personnel can access high-risk information. For example, seismic data marked as “Confidential” should be accessible only to members of the Data Processing and R&D departments.

Data Encryption and Security Controls: Use **Vormetric Data Security** Platform to encrypt sensitive data both at rest and in transit, ensuring that only authorized users with encryption keys can access classified information. This is particularly important for transferring and storing seismic data, intellectual property, and financial data.

Threat 10 – Lack of Disaster Recovery and Business Continuity Plan

Assumption

Without a formal DRP or BCP, the organization faces heightened risks of data loss and operational disruptions during disasters, such as fires or system failures in the data center.

Example

The organization regularly backs up seismic data and other critical information onto physical tapes, which are stored on open racks within the Data Processing Room. While these backups provide some redundancy, the company lacks a comprehensive Disaster Recovery Plan (DRP) and Business Continuity Plan (BCP). A physical disaster, such as a fire or flood, could destroy these backups, leading to irreversible data loss. In the event of a data loss incident, without an offsite backup or a tested recovery process, the company faces considerable risks of data loss and operational delays. the company could face legal liabilities from clients if seismic data essential to their operations is lost, along with financial repercussions and regulatory consequences for failing to protect sensitive information adequately.

Impact

Without a formal DRP and BCP, the organization is vulnerable to severe data loss, operational disruptions, and possible regulatory violations. A physical disaster could compromise critical client data, halting seismic data processing and affecting client services. This disruption would not only damage the company's reputation but could also result in significant financial losses if client projects are delayed. Additionally, the

lack of offsite backup increases the risk of losing critical client and proprietary data in a disaster, potentially resulting in client lawsuits and legal action for non-compliance with data protection requirements.

Mitigation

Implementation of a Disaster Recovery Plan (DRP) and Business Continuity Plan (BCP): Develop a DRP and BCP framework using **IBM Resiliency Orchestration**, which automates disaster recovery testing and enables fast recovery in case of system failures or disasters. IBM Resiliency Orchestration also allows for automated failover, ensuring continuity in operations even when primary systems are compromised.

Offsite Backup Storage: Store physical backup tapes securely with **Amazon Web Services (AWS)** to protect against data loss from onsite disasters. This offsite storage solution offers climate-controlled, secure locations, reducing risks from events like fire or flood.

Regular Testing and Validation of DRP/BCP: Implement **Veritas NetBackup** to conduct automated testing of backup and recovery processes. Regular testing validates data integrity and ensures that data can be restored quickly, minimizing downtime and protecting client deliverables.

Data Encryption for Backups: Encrypt all physical and cloud-based backup data using Symantec Data Loss Prevention (DLP), securing client seismic data against unauthorized access and ensuring compliance with legal and contractual obligations for data protection.

5.0 Best Practices for Implementing Identified Controls

Employee Training and Awareness (Phishing, Social Engineering, Policies and Procedures)

The organization faces substantial risk from social engineering attacks targeting sensitive R&D upcoming projects and current existing systems (e.g., SensorDrill, MeasureMe upgrades). With contractors, part-time staff, and multiple vendors interacting with employees, phishing attacks and social engineering tactics are highly plausible threats.

This control measure will include:

Comprehensive Security Awareness Programs: Use the SANS Security Awareness framework to create a personalized, multi-level training program addressing the organization's threats. Modules should cover phishing awareness, social engineering tactics, and essential company policies governing data handling and communication protocols.

Simulated phishing campaigns and social engineering tests: Regularly use Cofense PhishMe simulations to analyze employees' sensitivity to phishing attempts. Set out scenario-based social engineering exercises where staff practice verifying identities and responding to simulated threats.

Security Policy Familiarization and Compliance: Ensure that all employees understand, can implement, and adhere to the organization's entire set of security rules, including those governing data management, access control, and incident response. Essential IT department Employees should be ready to implement the Incident Response Plan (IRP) and Disaster Recovery Plan (DRP) into their daily operations as the organization plans future implementations.

- **Policy Knowledge Assessments:** Conduct regular quizzes and assessments to ensure that staff, particularly new employees and contractors, understand and follow security policies, including impending IRP and DRP initiatives.
- **Scenario-Based Training:** Use real-world case studies and simulations to reinforce policy implementation, allowing employees to practice (handling confidential R&D data, managing sensitive client data processing, IRP, and DRP) for higher preparedness in high-stakes situations.

- **Constant Policy Review:** Hold briefings and seminars when IRP and DRP are deployed to inform staff about policy changes, emphasizing new threats and updated recovery methods.

Advanced Email Filtering and Network Protection

The organization's emphasis on protecting sensitive communications connected to high-value R&D projects and important seismic data processing requires robust email filtering and network protection. This control measure will include:

Email Filtering Solutions: Deploy the Barracuda Email Security Gateway to proactively filter and block phishing emails and other malicious content before it reaches employees, especially those in high-risk departments like R&D, IT, and data processing, where threats could expose proprietary technology and client data.

Network Traffic Monitoring and DoS Protection: Cisco Firepower 1120 Series appliances continuously monitor and control network traffic, sending real-time notifications for any abnormal spikes that could indicate a DoS attack. These alerts allow IT teams to respond quickly to prevent disruptions to vital services such as real-time monitoring and data processing, which are critical to client operations.

Rate Limiting: Implement rate limiting through **Cloudflare** to restrict excessive traffic from single IPs, safeguarding client-facing services and R&D resources from overloads. This control is essential for maintaining service availability and preventing malicious actors from overwhelming network systems.

Periodic Testing and Auditing: Regularly audit email filtering efficiency and network protection measures to ensure they meet security standards.

Data Encryption and Intrusion Detection (IP Theft & Software Vulnerabilities)

Data Encryption: Use AES-256 encryption for data at rest on IP and client data servers, while securing data in transit with TLS encryption to prevent interception.

Firewall and Intrusion Detection: Implementing **Cisco Firepower 1120** with intrusion detection to identify and block vulnerabilities across the organization's network. Update firewall configurations regularly, prioritizing high-risk IP and client data.

Secure Coding Practices: Foster secure coding in R&D with regular code reviews and security audits, addressing vulnerabilities like SQL injection and buffer overflows.

Patch Management and Vulnerability Scanning: Implement a strict patching schedule on all servers and devices managing sensitive data. Use **Acunetix** for consistent vulnerability scans, ensuring patches are tested and applied without disrupting services.

Incident Response Plan (IRP) and Disaster Recovery Plan (DRP) Control Measures

Implementing robust IRP and DRP measures is essential for the organization, especially with its high-value intellectual property, sensitive seismic data processing, and ongoing R&D projects. These control measures ensure that the organization can effectively respond to incidents and recover critical operations in case of a disaster.

Implementing IRP

The IRP focuses on minimizing damage, managing risk, and restoring normal operations quickly in response to security incidents like cyberattacks, data breaches, or system failures. Key control measures include:

Incident Detection and Reporting:

- Utilize a Security Information and Event Management (SIEM) system, such as Splunk, to continuously monitor security events, suspicious activities, and anomalies across the network.
- Establish a centralized incident reporting system where employees can report potential incidents immediately, particularly in high-risk departments like R&D, IT, and data processing.

Establish an Incident response team (IRT)

- Create a designated IRT comprised of IT, security, legal, and communication professionals. This team is responsible for responding to occurrences following established protocols.
- Assign distinct roles within the IRT (e.g., incident handler, communications lead, forensic analyst) to simplify tasks during an event.

Implementing Disaster Recovery Plan (DRP)

The DRP ensures that the organization can restore critical operations quickly following a disaster, such as natural disasters, major system failures, or severe cyberattacks. Control measures include:

Data Backup and Recovery:

- Implement regular, automated backups for all critical data (e.g., seismic data, R&D files) using both on-premises (**Dell EMC Data Domain 3300**) and cloud-based solutions (e.g., **Amazon Web Services**).
- Ensure backups are encrypted, stored securely, and isolated from the main network to prevent ransomware infections.
- Conduct routine backup and recovery tests to ensure data can be restored quickly and accurately. Include both partial and full restoration tests to verify data integrity.

Access Controls – Role-Based Access Control (RBAC)

Given the highly sensitive seismic data and proprietary information managed in **Data Processing** and **R&D**, implementing role-based access controls is critical to limit data exposure and maintain compliance with data protection standards.

This control measure will include:

Role-Based Access Implementation: Deploy **Microsoft Azure Active Directory (AD)** to enforce RBAC across all departments, ensuring that access to seismic data, project files, and financial records is restricted to personnel with a need-to-know.

Quarterly Access Reviews: Conduct routine audits, particularly for R&D and data processing teams, to ensure permissions align with job roles, revoking access when employees no longer need it.

Activity Monitoring in High-Sensitivity Areas: Use **Microsoft Azure Security Center** to detect unusual access patterns in sensitive departments, allowing rapid response to unauthorized attempts.

Regular Backups

The organization must implement regular, secure backups to safeguard critical client data and proprietary information. The high stakes in seismic data processing and proprietary software management make routine data backup and storage essential.

This control measure will include:

Automated Backup System: Implement **Dell EMC Data Domain 3300** to automate backup procedures for seismic data and R&D files, maintaining redundancy without impacting operations.

Offline Backup Storage Policy: Store backup copies offline, away from the main data center, to protect against ransomware and other cyber threats targeting online data.

Monthly Backup Integrity Tests: Conduct tests every month to ensure backup data can be restored promptly and that files remain intact, safeguarding client data and proprietary information.

Data Encryption of Backups: Encrypt all backup data to maintain data confidentiality, even if copies are stored offsite or transferred for storage, reducing exposure to unauthorized access.

Secure Wireless Networks

The organization's internal wireless networks, particularly those supporting **R&D** and **Data Processing**, require secure segmentation and monitoring to prevent unauthorized access and ensure data integrity.

This control measure will include:

Cisco Meraki MR56 Implementation: Deploy **Cisco Meraki MR56** access points to segment and secure wireless networks, creating isolated channels for departments handling proprietary data.

Unique Credentials and Guest Network Isolation: Set up unique credentials for internal access, with separate guest networks for visitors and contractors, reducing the risk of unauthorized access to critical systems.

Real-Time Network Monitoring: Monitor network traffic continuously to identify potential breaches, focusing on departments handling sensitive seismic and R&D data.

Regular Security Configurations Update: Periodically review and adjust wireless security configurations to counteract evolving threats and maintain secure network environments.

Wireless Intrusion Prevention System (WIPS)

Protecting the organization's wireless infrastructure from unauthorized access attempts is essential in safeguarding proprietary R&D data and seismic processing information.

This control measure will include:

Aruba ClearPass Deployment: Deploy Aruba ClearPass for continuous monitoring of wireless traffic, providing real-time alerts on unauthorized access attempts in high-security zones such as the Data Centre on Level 5.

Automated Blocking of Unauthorized Devices: Integrate WIPS with access control systems to instantly prevent unrecognized devices from connecting to the network.

Quarterly Wireless Security Audits: Conduct quarterly assessments using Ekahau Pro to ensure optimal wireless security and to adapt configurations to the latest threat landscape.

Staff Training on WIPS Alerts: Train IT staff to respond to WIPS alerts effectively, ensuring timely action against detected wireless security breaches.

Password Policy Enforcement

A centralized management approach is crucial to ensure strong password security, especially in departments dealing with sensitive data and client information. This control measure will include:

Centralized Management with LastPass Enterprise: Use **LastPass Enterprise** to manage and enforce password policies, ensuring secure sharing of login credentials when necessary.

Complex Password Requirements: Set strict policies for complex passwords that must be regularly updated, minimizing the risk of credential compromise in high-risk departments.

Multi-Factor Authentication (MFA) Enforcement: Require MFA for all sensitive systems, especially those within the **Data Processing** and **R&D** departments.

Routine Password Training: Provide regular training to emphasize the importance of secure passwords, particularly for employees with access to critical systems.

Regular Security Audits

Routine security audits of wireless and physical infrastructure are essential for identifying vulnerabilities and strengthening defense against unauthorized access. This control measure will include :

EkaHau Pro for Security Audits: Use **EkaHau Pro** to conduct in-depth security audits of the wireless network and physical access points to detect potential weaknesses.

Quarterly Audits for High-Risk Areas: Focus on high-risk areas, such as **Data Processing** and **Server Rooms**, and prioritize addressing vulnerabilities found in these locations.

Remediation and Policy Updates: Immediately address vulnerabilities identified in audits, updating security policies to incorporate new measures for enhanced protection.

Audit Documentation and Review Process: Maintain detailed audit reports to track progress over time, using insights to improve future security practices and maintain compliance.

Employee background screening

Unverified employees pose a serious threat to the physical security of the organisation. If left unchecked, they might come with malicious intentions and intrude into unauthorised areas or rooms to access or tamper sensitive devices and data. They can cause significant damage as since they are full-time employees, they will have access to the company premises, and depending on their roles, they can potentially access the critical IT infrastructure and information.

Screening is especially important for cyber security and software development employees as they will have more access than employees of other departments. Control measures to include:

Checkr: A background check and employment screening company that streamlines and automates background checks for hiring. It provides services for quickly verifying information about candidates, such as criminal records, driving history, and employment history. This will assure hired employees and ensure that they are moral and ethical individuals who will work in the organization's best interests.

Physical intrusion prevention

Unsupervised visitors or contractors can breach physical security if they are left to roam the premises unchecked. They could access sensitive areas like management offices or server and wiring rooms. This could allow them to access and tamper with vital data and devices.

Control measures include:

Hikvision security cameras: Dome cameras will be installed indoors. These cameras offer 360 degree views which makes them ideal for monitoring large spaces like the offices and hallways. Their shape makes them discreet which makes it difficult to tell whether the cameras are actively being used.

Bullet cameras will be installed outdoors to monitor the surrounding areas of the premises. They have a long viewing range, making them ideal for monitoring open outdoor spaces and ensuring clear footage across large distances.

RFID: Critical locations like server rooms, wiring closets and employee offices, will be secured using RFID technology. Anyone accessing these rooms will require RFID keycards. These keycards will only be given to employees based on their roles to ensure only those who require access are given it.

Each time the RFID card is used, it will be logged in a monitoring system to check who is accessing which room. These keycards can also be disabled or locked in case they are lost or stolen. This will provide additional security to ensure any attackers or intruders cannot access important areas.

Supervised visits: Visitors and contractors will be accompanied and supervised by a member of security. This will ensure that they only do their required tasks and they exit the premises after finishing without wandering around.

Fire safety

There can be risks of electrical fires breaking out in the wiring closets and server rooms. Fires can cause serious damage if they are not put out in time. They can extensively damage the rooms, devices, and employees of the organization.

Control measures include:

Naffco fire extinguishers and sprinklers: Sprinklers will be installed across the company office rooms and hallways. Fire extinguishers will be set up in stairways and other common areas for easy access.

Fire evacuation plans: Evacuation plans are made to ensure everyone can exit the premises safely if a serious fire breaks out. It will also contain instructions on what steps to take to minimize the fire damage to the office, devices, and employees.

5.1 Minimum Due Diligence

The organization must focus on security solution updates, robust incident handling, and employee training to meet the minimum requirements. Key measures include:

Access Controls – Role-Based Access Control (RBAC)

Minimum due diligence for role-based access includes:

- **Access Review Process:** Implement quarterly reviews with **Microsoft Azure AD** to ensure permissions are up-to-date, with a focus on high-risk areas such as **Data Processing** and **R&D**.
- **Conditional Access for High-Risk Roles:** Enforce conditional access policies in Azure AD for roles involving sensitive data, limiting access based on factors like device and location.
- **Documentation and Audit Trails:** Maintain comprehensive logs of access requests and changes, especially for personnel handling sensitive seismic data and proprietary information.

Regular Backups

Minimum due diligence to secure data backups includes:

- **Automated Backup Schedule:** Configure **Dell EMC Data Domain 3300** to conduct daily backups for high-priority data (e.g., seismic data), ensuring redundancy for critical information.
- **Weekly Integrity Checks:** Perform weekly integrity checks to verify that backup data is complete and recoverable.
- **Encryption of Backup Data:** Ensure all backup data, particularly physical tapes, is encrypted to protect client and proprietary data during storage and transit.

Secure Wireless Networks

Minimum due diligence for wireless security includes:

- **Segmentation with Cisco Meraki MR56:** Use **Cisco Meraki MR56** to create separate network segments for sensitive areas, ensuring isolated access for departments like **R&D** and **Data Processing**.
- **Access Credential Management:** Require unique credentials for internal networks, and ensure that guest networks are separated from the main internal infrastructure.

- **Quarterly Network Performance Reviews:** Perform quarterly reviews of network usage patterns to verify compliance with access restrictions and detect potential unauthorized access.

Wireless Intrusion Prevention System (WIPS)

Due diligence for preventing unauthorized wireless access includes:

- **Continuous Monitoring with Aruba ClearPass:** Ensure **Aruba ClearPass** actively monitors all wireless connections, issuing alerts on suspicious access attempts.
- **Quarterly Wireless Security Assessments:** Perform wireless security assessments quarterly with **EkaHau Pro** to ensure no vulnerabilities exist within high-risk zones.
- **Documentation of Unauthorized Access Attempts:** Maintain detailed records of WIPS logs, documenting any attempts at unauthorized access for future audits and trend analysis.

Regular Security Audits

Minimum due diligence for maintaining robust security involves:

- **Quarterly EkaHau Pro Audits:** Conduct quarterly audits using **EkaHau Pro** to review both physical and wireless access, focusing on areas housing critical assets.
- **Vulnerability Remediation Timeline:** Implement a policy requiring the remediation of any high-priority vulnerabilities identified during audits within 30 days.
- **Policy Updates Based on Findings:** Update organizational security policies based on audit results, addressing any discovered weaknesses in the current security framework.

Password Policy Enforcement

Minimum due diligence for enforcing secure password practices includes:

- **LastPass Enterprise Deployment:** Implement **LastPass Enterprise** for centralized password management, with enforced complexity and update requirements.
- **MFA Requirement for Sensitive Accounts:** Require MFA for all critical systems, particularly for high-risk departments like **Data Processing**.
- **Quarterly Password Compliance Review:** Review password compliance and update history every quarter, ensuring all active accounts meet the required complexity and expiration standards.

Employee background screening

Minimum due diligence for background screening includes:

- **Identity Verification:** Confirm the candidate's identity through government-issued identification to prevent any identity fraud.
- **Employment Verification:** Verify their past employment to confirm that the candidate has the experience they claim, including job titles, employment dates and reasons for leaving their previous job.
- **Criminal Record Check:** Review their criminal history to ensure they have a clean record to prevent any risks.

Physical intrusion prevention

Minimum due diligence includes:

- **Legal compliance:** When setting up the CCTV cameras, the laws for surveillance and monitoring should be followed. Cameras should only be set up where they are allowed, such as in common public areas. Employee privacy should not be violated. Employees should also be notified that the premises are under CCTV surveillance.

- **RFID security:** When setting up the locks, ensure that RFID signals are encrypted to prevent unauthorized cloning or hacking of the access cards. Any lost or stolen keycards should be immediately revoked or disabled to prevent attackers from using them.
- **Securing the logbook:** Visitor logbooks should be kept secure in the security office. Only authorized members of the security team can access it and make entries. Visitors and contractors should not be allowed to see the book. Securing is important to prevent any forged entries or deletion of existing entries.

Fire safety

Minimum due diligence includes:

- **Sprinkler Placement:** Position sprinklers to cover all critical areas, including data storage, employee offices, servers, and wiring rooms. Ensure that obstacles do not block sprinklers and provide adequate coverage throughout the premises.
- **Regular maintenance:** The sprinklers and extinguishers should be regularly inspected, and maintenance should be done to ensure they remain functional.
- **Fire safety awareness:** Train employees on proper fire extinguisher usage) and ensure they know the location of extinguishers throughout the premises. Conduct regular fire drills to educate employees on evacuation routes, fire exits, and emergency procedures to mitigate fire hazards effectively.

5.2 Key Considerations

When implementing these controls, attention must be given to integration, compliance, employee engagement, and the organization's resources and assets:

Compatibility and Integration

System Cohesion: Ensure new tools like anti-phishing software, MFA, and IDS align with existing systems to avoid operational interruptions. For instance, integrating Cisco Firepower for DoS protection with current network monitoring is essential to ensure seamless protection across R&D and data processing units.

Compliance with Industry Standards

Alignment with regulations: Implement compliance measures per ISO 27001, GDPR, or other relevant standards, focusing on data encryption, backup integrity, and employee security training, given the sensitivity of client seismic data and proprietary IP.

Employee Engagement and Accountability

Security Culture: Involve employees in cybersecurity practices to foster a security-aware workplace, emphasizing the importance of cybersecurity measures, particularly in departments managing sensitive projects (IT, R&D, etc.).

Cost-Effectiveness and Budget Allocation

Prioritizing Investments: Allocate budgets to high-impact, cost-effective security solutions that address major threats identified in workshops (e.g., phishing training, endpoint protection, SIEM for monitoring), balancing costs with essential security improvements.

Compliance with laws and regulations

Employee screening: When conducting background screening for employees, the local law regulations must be followed. Only employee information that is legally allowed to access should be used. The background screening must not infringe upon employee privacy and legal rights.

Employee monitoring: Any measures set up to monitor employee activities through cameras or applications on their devices must be done in compliance with the law. They should be implemented only if it is permitted and does not violate their privacy.

5.3 Metrics and Measurements

To assess the effectiveness of implemented controls, tracking key metrics that focus on the success and efficiency of implemented solutions (All the security controls and measures added) is vital for the long-term planning and sustenance of the organization.

Training Effectiveness

Phishing Training/Simulation Success Rate: Measuring the percentage of employees who successfully identified phishing emails, aiming for an annual improvement. Tracking the training effectiveness for high-risk departments (e.g., R&D) and adjusting the program as needed based on performance.

Email Filtering and Network Security

Phishing/Spam Email Block Rate: Monitor the volume of blocked phishing emails monthly using the **Barracuda Email Security Gateway**, and analyze trends to identify patterns or specific department targets.

DoS Detection and Mitigation Frequency: Track the number and types of DoS attacks detected and mitigated using Cisco Firepower, aiming to maintain uninterrupted network availability for critical departments like data processing.

Access Controls – Role-Based Access Control (RBAC)

- **Access Violation Reports:** Record the number of access violations and unauthorized attempts within **Microsoft Azure AD**, particularly in sensitive departments.
- **Access Review Completion Rate:** Measure the percentage of access reviews completed each quarter, ensuring compliance with RBAC policies.
- **Response Time to Access Revocations:** Track the average time taken to remove access for employees whose roles change or who leave the company.
- **Audit Log Analysis:** Regularly analyze audit logs for unusual access patterns, identifying trends that may signal security weaknesses.

Regular Backups

- **Backup Success Rate:** Measure the success rate of daily backups on **Dell EMC Data Domain 3300** to ensure data integrity for critical client and proprietary information.

- **Data Recovery Time Objective:** Assess how long it takes to restore data from backups, ensuring that the RTO meets the organization's operational requirements.
- **Backup Integrity Checks:** Track the frequency of successful backup integrity tests to confirm that data remains uncorrupted and retrievable.
- **Encrypted Backup Verification:** Monitor encryption status across all backups, ensuring all stored data is properly encrypted, especially for offsite storage.

Secure Wireless Networks

- **Unauthorized Access Attempt Rate:** Record the number of unauthorized access attempts detected on the network, especially for segments used by **R&D** and **Data Processing**.
- **Network Traffic Anomalies:** Use network traffic analysis to detect anomalies that could indicate potential security breaches.
- **Guest Network Segregation Compliance:** Audit guest network segregation quarterly to ensure compliance and avoid any crossover with sensitive internal networks.
- **Configuration Update Frequency:** Track the frequency of configuration updates on **Cisco Meraki MR56** to ensure security measures remain current and effective.

Wireless Intrusion Prevention System (WIPS)

- **Unauthorized Device Detection Rate:** Monitor the frequency of unauthorized devices attempting to access the network, as flagged by **Aruba ClearPass**.
- **Time-to-Resolution for WIPS Alerts:** Measure the time taken to respond to and resolve WIPS alerts to ensure prompt handling of unauthorized access attempts.
- **Coverage Analysis:** Regularly check WIPS coverage across critical areas (e.g., **Data Centre on Level 5**) to ensure that high-risk zones are continuously protected.
- **Quarterly Audit Compliance:** Track the completion of quarterly audits to verify ongoing WIPS effectiveness and address any security gaps.

Regular Security Audits

- **Vulnerability Remediation Time:** Measure the time taken to resolve high-priority vulnerabilities identified during audits, aiming for remediation within the 30-day target.
- **Audit Completion Rate:** Ensure quarterly audits are completed for high-risk areas like **Data Processing** and **Server Rooms**, tracking consistency over time.
- **Policy Update Implementation Rate:** Track the number of security policy updates implemented post-audit to ensure findings are addressed and integrated into the organization's security framework.
- **Compliance with Regulatory Standards:** Monitor adherence to regulatory compliance standards in audit findings to avoid potential fines or sanctions.

Password Policy Enforcement

- **Password Complexity Compliance Rate:** Track compliance with password complexity requirements, especially among employees in **Data Processing** and **R&D**.
- **Password Expiry Adherence Rate:** Measure adherence to password expiration policies, ensuring timely updates to maintain credential security.
- **MFA Adoption Rate for Sensitive Accounts:** Monitor MFA usage on accounts with access to sensitive data to verify adherence to policy requirements.
- **Password Reset Frequency:** Track the number of password resets requested, as unusually high rates could indicate potential password sharing or compromise.

6 Asset Evaluation Table

General Assumptions

- **Lifecycle and Depreciation:** Strategic and operational assets have a 5-year lifecycle with scheduled upgrades and replacements, particularly for servers, network equipment, and environmental monitoring systems.

- **Maintenance and Security:** All critical assets undergo regular security updates, maintenance checks, and performance monitoring, minimizing risks and downtime.
- **Scalability and Redundancy:** Core assets such as servers, storage devices, and firewalls are chosen for their scalability, enabling the company to meet growth demands without compromising on data security or operational efficiency.
- **Budget Allocation:** Approximately 60% of the budget supports strategic and operational assets, while the remaining 40% covers compliance, auxiliary assets, and maintenance services.
- **The Company Value:** The company controls 40% of the global market, and according to the ***In-depth Industry Outlook: Oil and Gas Software Market Size & Forecast (2024)*** report, the current market is worth 1.25 billion, which means $1.25\text{billion} \times 0.4 = 0.5\text{billion}$ (USD) our organization has estimated annual value of 500 million in 2024.

Asset Assumptions

With an estimated annual budget allocation of \$10 million for IT infrastructure and security, values are distributed based on each asset's contribution to organizational stability, data protection, and operational continuity.

Strategic Assets: Assets critical to maintaining data integrity, operational continuity, and security are assigned the highest values. These include core networking equipment (firewalls, switches), data storage solutions, and backup systems.

- Examples: **Cisco Firewall, Dell EMC Data Domain 3300, HP ProLiant Gen9 Servers, Cisco ISR Router**
- **Assumptions:** Strategic assets must deliver reliable performance to prevent any disruptions to critical data processes, protect against cyber threats, and support high data availability for R&D and Data Processing departments.

Operational Assets: Assets essential to supporting day-to-day company operations and employee productivity are valued for their role in enabling communication, data processing, and environmental stability.

- Examples: **Cisco Access Points, Hikvision Cameras, CoolIT Cooling System, APC Netbotz Environmental Monitoring**
- **Assumptions:** Operational assets are crucial for providing secure and stable infrastructure across all levels, ensuring employee access to essential resources, and protecting sensitive data. Regular maintenance and real-time monitoring are assumed for these assets to minimize downtime and optimize functionality.

Revenue-Generating Assets: Assets directly used in revenue-generating departments such as R&D and Data Processing are prioritized based on their role in competitive product development and data analysis.

- Examples: **IBM Blade Center, Dell Precision Desktops and Laptops, Tape Backup**
- **Assumptions:** These assets are allocated higher values due to their direct impact on data processing, seismic data handling, and the competitive product development pipeline. Regular upgrades are anticipated to maintain performance standards.

Support and Auxiliary Assets: These assets support general company operations and employee wellbeing, representing essential but indirect contributions to company revenue.

- Examples: **Network Cables and Points, Visitor and Contractor Badges, Hungerbuster Vending Machines, Printmaster Photocopiers and Printers**
- **Assumptions:** Support assets are essential for a functional office environment and are maintained to ensure smooth daily operations and a secure workspace. These assets contribute indirectly to overall productivity and security.

Hardware & Networking Components Asset Table

Name	Asset Type	Manufacture Model/Name	Physical Location	Value (USD)
Access Control Badges and Readers	Access Control Reader	HID iClass SE Readers R90	Entrances to Sensitive Areas, Levels 4 & 5	250 each. (250 x 10) 2,500
CoolIT Systems	Cooling System	Omni AA1	Data Centre, Level 5/ Roof	3,500
APC Netbotz	Environmental Monitoring	NBWL0756	Data Centre and Server Room, Levels 4 & 5	1,400
Printmaster Photocopiers and Printers	Printer/Photocopier	Managed by Printmaster Pty Ltd	Throughout Premises, Levels 1-5	3,000 (Lease) each. (3,000 x 7) 21,000
Network Cables and Points	Networking Infrastructure	Installed by Computex Pty Ltd	Throughout Premises, Levels 1-5	2,000
Hungerbuster Vending Machines	Food and Drink Dispenser	Provided by Hungerbuster Pty Ltd	Common Areas, Levels 1-5	1,050 each. (1,050 x 3) 3,150
Visitor and Contractor Badges	Identification System	Provided by PeopleRus	Reception Desk, Level 1	250
Fire Alarms and Smoke Detectors	Fire Detection System	Kidde Smoke Alarm Detectors	Throughout all floors, Server Room, Data Centre	40 each. (40 x 20) 800

Dell Desktop	Desktop Computer	Optiplex 360	Various Offices, Levels 1-5	400 each. (400 x 200) 80,000
Dell Precision Desktops and Laptops	Desktop and Laptop	Precision Series	Various Departments, Levels 1-5	1,300 each. (1,300 x 250) 325,000
Cisco AP	Access Point	Cisco 1242AG	Various Departments, Levels 1-5	470 each. (470 x 5) 2,350
Cisco IP	IP Phone	Cisco 7941G	Various Departments, Levels 1-5	520 each. (520 x 5) 2,600
Konica Minolta MFG	Multifunction Printer	Konica Minolta C350	Various Departments, Levels 1-5	5,000 each. (5000 x 5) 25,000
Cisco Switch (Levels 1 to 5)	Access Switch	Cisco 2960	Various Departments, Levels 1-5	200 each. (200 x 5) 1,000
Cisco 3750E (multiple instances)	Core Switch	Cisco 3750E	Various Departments, Levels 1-5	1,300 each. (1,300 x 3) 3,900
VOIP Server	Server	Cisco	Server Room, Level 4	900
Domain Controller	Server	HP ProLiant Gen9	Server Room, Level 4	5,500
File & Print Server	Server	HP ProLiant Gen9	Server Room, Level 4	5,500
Web Server	Server	HP ProLiant Gen9	Server Room, Level 4	5,500
Tape Array	Data Storage	HP 1/8 G2	Server Room, Level 4	1,400

Voice Gateway	Gateway	Cisco	Server Room, Level 4	700
Cisco ISR	Integrated Services Router	Cisco 3845	Server Room, Level 4	3,000
IBM Blade Center (multiple instances)	Blade Server	IBM	Data Processing Room, Level 5	800 each. (800 x 4) 3,200
Tape Backup	Backup Device	HP 1/8 G2	Data Processing Room, Level 5	1,400
Cisco Firewall	Network Security	Cisco Firepower 1120 Series	Throughout Premises, Levels 1-5	2,800

Table 1. Hardware and networking components

Roles Assumptions

With a 2024 revenue estimate of \$500 million, we can now distribute values across each role based on its contribution, as previously outlined:

- High-impact strategic roles (e.g., CEO, Chief Information Officer, Chief Security Officer) will be assigned values based on their critical role in maintaining the company's market leadership.
- Revenue-generating roles (e.g., R&D, Data Processing) will be valued highly due to their direct impact on competitive product development and revenue growth.
- Operational and security roles will support company operations and compliance, receiving moderate values.
- Administrative and contracted roles will receive smaller values, representing essential but indirect contributions to revenue.
- The organization currently employ 500+ staff members across the organization.

People Asset Table

Position Name	Position ID	Special Skills	Estimated Annual Value (USD)	Assumptions for Value
CEO	P-001	Strategic leadership	\$15,000,000	Leads company strategy, market positioning, and high-stakes decision-making, crucial for revenue growth.
Chief Information Officer/Chief Information Technology Officer (CIO/CTO)	P-002	Security governance, risk mgmt.	\$5,000,000	Oversees IT infrastructure, cybersecurity, and regulatory compliance, essential for data integrity.
Chief Security Officer	P-003	Cybersecurity, policy development	\$6,000,000	Manages security policies and compliance, critical for protecting data and proprietary software.
Director, Data & Product	P-004	Data governance, product dev.	\$4,000,000	Oversees data management and client relations, impacting customer satisfaction and data reliability.
Division Head - Research & Development	P-005	Innovation, SensorDrill dev.	\$10,000,000	Leads high-revenue R&D projects, including key product upgrades

				essential for market share growth.
Division Head – Software	P-006	Software engineering	\$3,500,000	Manages software lifecycle and innovation, supporting product development and client satisfaction.
Division Head - Data Processing	P-007	Seismic data analysis	\$5,000,000	Optimizes data processing efficiency, directly contributing to faster project turnaround and revenue.
Division Head - Service & Technical Support	P-008	Customer service	\$2,500,000	Enhances customer support and satisfaction, vital for maintaining client relationships and loyalty.
Director - Back Office	P-009	Admin oversight, policy implementation.	\$1,500,000	Ensures smooth administration and policy implementation, supporting day-to-day business stability.
Sales and marketing manager	P-010	Oversees the sales and marketing of the software to the clients.	\$1,500,000	Runs the whole marketing campaign, played a huge role in marketing the software, and will ensure smooth

				marketing for our upcoming projects.
Manager, Building & Maintenance	P-011	Facility management	\$1,000,000	Maintaining safe and functional facilities (server/data processing rooms) is essential for workplace operations and physical security.
Manager, Office Administration	P-012	Office operations	\$1,000,000	It supports administrative functions, which are crucial for smooth daily operations.
Manager, Finance	P-013	Budgeting, financial planning	\$2,500,000	Manages financial planning, budget allocation, and fiscal health, indirectly supporting revenue.
Manager, Human Resource	P-014	Talent management	\$1,500,000	Supports workforce stability, policy compliance, and recruitment, essential for team productivity.
Manager, Legal Department	P-015	Legal compliance	\$2,000,000	Oversees legal compliance and mitigates risk, helping avoid potential penalties or legal challenges.
Legal Officer	P-016	Contract mgmt., compliance	\$1,000,000	Assists in contract and compliance

				management, helping avoid legal and compliance risks.
IT Staff	P-017	System security, data backup	\$2,000,000	Supports IT security and data integrity, crucial for preventing data breaches or operational disruptions.
R&D Staff	P-018	Product research	\$7,500,000	Directly contributes to high-revenue R&D projects, essential for competitive market positioning.
Data Processing Staff	P-019	Data analysis	\$3,500,000	Enhances data processing efficiency, improving project speed and output volume for revenue growth.
Technical Support Staff	P-020	Client support	\$1,500,000	Provides issue resolution and client support, essential for maintaining client satisfaction.
Security Officers	P-021	Physical access control	\$100,000	Ensures security and access control, protecting physical assets and sensitive areas.

Administrative Staff	P-022	Administrative support	\$850,000	Provides essential administrative support, helping maintain workflow and manager support.
Finance Staff	P-023	Financial analysis	\$850,000	Supports financial reporting and budgeting, indirectly supporting fiscal health and planning.
Human Resource Staff	P-024	Employee relations	\$750,000	Supports HR compliance and employee relations, contributing to workforce stability.
Legal Department Staff	P-025	Contract Compliance	\$850,000	Assists with compliance tasks, reducing the risk of legal penalties.
Sales and Marketing Staff	P-026	Run ads and maintain the organization's social media presence	\$700,000	The staff comprises personnel who run the organization's sales and marketing department.
Contracted Cleaners	P-026	Environmental upkeep	\$250,000	Maintains cleanliness and hygiene, essential for a comfortable and safe work environment.
Contracted Network Technicians	P-027	Network cabling	\$350,000	Ensures network connectivity and infrastructure

				maintenance, supporting IT stability.
Vendor Support Staff	P-028	Equipment maintenance	\$400,000	Maintains office equipment (e.g., printers, copiers), supporting daily operational efficiency.

Table 2. People assets

Assumptions for the Data Asset Table

- The value of the assets is also based on the organization's value of 500 million.
- Revenue and Strategic Importance: High-value assets (e.g., SensorDrill, MeasureMe) are crucial for revenue generation and market growth.
- Industry-critical assets (e.g., Seismic Data, Network Configuration) support technological and operational leadership.
- Lower-value assets (e.g., Visitor Data, Employee Training Records) contribute indirectly to organizational success.
- There is no mathematical formula for calculating these assets' value.

Data Asset Table

Data Asset	Classification	Owner	Estimated Value (USD)	Assumption for Value

SensorDrill	Confidential	Division Head - R&D	\$30,000,000	Essential for a high-revenue project that enhances market share; critical for strategic development.
MeasureMe	Confidential	Division Head - Software	\$30,000,000	Important for client deliverables and maintaining competitive product offerings; directly tied to revenue.
Shake and Quake Seismic Data	Top Secret	Division Head - Data Processing	\$10,000,000	Proprietary and essential for specialized services; high strategic importance and revenue impact.
Employee Information	Confidential	Manager - Human Resource	\$5,000,000	Supports HR compliance and workforce management; essential but with moderate strategic value.
Financial Records	Confidential	Manager - Finance	\$10,000,000	Crucial for financial planning, audits, and strategic decisions; impacts operational health.

Client Contracts and Legal Docs	Confidential	Manager - Legal Department	\$7,000,000	Important for maintaining client relationships and ensuring compliance; moderate value.
Incident Response Logs	Confidential	Chief Security Officer	\$8,000,000	Critical for managing security incidents and ensuring compliance with security protocols.
Vendor Agreements	Confidential	Director - Back Office	\$3,000,000	Supports vendor management and operations; lower strategic importance.
Network Configuration Data	Confidential	Chief Information Technology Officer	\$12,000,000	Essential for maintaining IT infrastructure, security, and quick recovery in case of failures.
Archived Seismic Data Reports	Confidential	Division Head - Data Processing	\$6,000,000	Used for historical reference and future analysis; contributes to long-term strategic planning.

Employee Training Records	Confidential	Manager - Human Resource	\$2,000,000	Supports compliance and staff development; lower revenue impact but necessary for operations.
Backup Data	Confidential	Chief Information Officer	\$25,000,000	Ensures business continuity and data integrity; highly valuable for protecting other critical assets.
Visitor Data	Confidential	Chief Security Officer	\$500,000	Used for security verification; minimal impact on overall operations.

Table 3. Data assets

Procedure assets:

Assumption: These are the important procedure assets that the organization currently employs as well as future procedures that the organization will set up as part of its mitigations and defense strategies. The value of these assets has been taken based on how vitally important they are to follow for the operations and security of the organization.

Procedure	Description	Intended purpose	Software/hardware /networking elements	Procedure documents location	Value (\$)

Visitor management procedure	Process of handling incoming visitors	Signing in and verifying visitors to ensure they are legitimate	Visitor logbook	Security office	450,000
Contractor and vendor access procedure	Allowing cargo lift access to vendors and contractors	Securely providing access to vendors and contractors	Contractor/vendor logbook, cargo lift	Security office	510,000
Data processing backup procedure	Backup client data stored on the tapes in the data processing room	Securely backup sensitive client data for reliable and smooth recovery.	HP 1/8 G2 Tape Loader, Symantec Backup Exec software.	Data processing room	300,000
Server backup procedure	Backup organizational data stored on the servers in the server room.	Secure and store company data for disaster recovery.	HP ProLiant Gen9, Windows 2016 server, HP 1/8 G2 Tape Autoloader, Symantec Backup Exec software.	Server Room	500,000
Server and wiring rooms access control Procedure	Process of locking and unlocking the server rooms and wiring closets	Protect the servers and other networking hardware devices from unauthorised access.	RFID locks and keycards, RFID logging system	CSO office	525,000
Client PC security procedures	Procedure for managing client PC configuration like applications, firewall, software updates and antivirus.	Ensure security and reliability of the devices.	Dell Optiplex 360 desktop, Dell precision laptops, Windows 10 pro,	CSO office	360,000

Password policy	Policy for creating new user accounts and educating new employees on password security.	Ensure employees create strong and secure passwords and regularly change them to secure their accounts and sensitive data.	Microsoft account, domain controller server	CSO office	200,000
Security auditing procedures	Process of conducting regular vulnerability assessments and pen testing to assess the security of all components.	Ensure that all the different security measures in place are operational working effectively.	PCs, servers, networking components, vulnerability scanners, firewalls, antivirus.	CSO office	450,000
Fire evacuation protocols	Process for safely exiting the premises or during a fire or putting out the fire.	Ensure that everyone is aware of what should be done to put out fires or evacuate the premises if required.	Fire extinguishers, Fire alarms, sprinklers	All rooms in the premises	722,500
Fire equipment maintenance procedure	Process for the routine maintenance and testing of fire safety equipment like alarms,	Ensure that fire equipment is correctly functioning and operational.	Fire extinguishers, Fire alarms, sprinklers	Building maintenance office.	490,000

	extinguishers and sprinklers.				
--	-------------------------------	--	--	--	--

Table 4. Procedure assets

Software assets:

Assumption: These are

the important software assets that the organization currently owns, as well as future assets that the organisation will acquire as part of its mitigations and defense strategies.

The costs of these assets have been taken based on their current retail prices as well as from the scenario.

Name	Description	Intended purpose	Value/Cost
SensorDrill	Software use by clients to monitor the drilling of oil and gas wells.	To analyse the drilling performance and ensure efficient and safe drilling operations.	\$10,000,000 Additional \$100,000,000 after project 1 completion.
MeasureMe	Software used by clients to monitor the pumping of oil and gas	To optimize pumping operations and monitor and analyse performance.	\$10,000,000 Additional \$100,000,000 after project 1 completion.
Shake and Quake	Organisational software for processing and interpreting seismic client data and providing reports.	Provide comprehensive reports to clients about their processed seismic data.	\$8,000,000 Additional \$100,000,000 after

			project 1 completion.
Project 1 software	Top Secret	Division Head - R&D	\$100,000,000
Project 2 software	Software that will distribute data processing between many servers so the data processing software can process data quicker.	To reduce processing time and increase efficiency of data processing.	\$30,000,000
Acunetix	Web security vulnerability scanner	To scan for vulnerabilities in the web applications to ensure they are secure from different attacks.	\$16,000 annually
Cofense Phishme	Phishing simulation and response platform	To train employees on phishing threats	\$12,000 annually
Barracuda Email Security Gateway (model 300)	Email security gateway	To protect against email-based threats	\$1,680
okta identity cloud	Identity and access management	To manage user identities and secure access to applications	\$72 per user annually
Microsoft Azure AD	Cloud-based directory and identity management	To manage access control, authentication and identity for users	\$144 per user annually
Sophos Intercept X	Endpoint protection software	To detect and prevent malware on devices	\$30 per user annually
Selenium	Automated testing software	To automate web application testing	\$0 (open source)
Bugzilla	Bug tracking software	To track and manage software bugs	\$0 (open source)
Tripwire	Security and compliance software	To monitor changes to critical systems and ensure compliance	\$1,500 annually

Nagios	IT infrastructure monitoring	To monitor network and infrastructure performance	\$0 (open source)
APC Netbotz	Environmental monitoring solution	To monitor environmental conditions in data centers	\$4,490 annually
Aruba ClearPass	Network access control	To enforce security policies for network access	\$4,000
Ekahau Pro	Wi-Fi design and analysis tool	To design and optimize wireless networks	\$5,440 per license
LastPass Enterprise	Password management solution	To securely manage passwords for employees	\$72 per user annually
SANS Security	Cybersecurity training software	To provide cybersecurity training to employees	\$8,000 per course
SolarWinds Access Rights Manager	Access rights management	To control and audit access to sensitive data	\$2,000 annually
Blancco Drive Eraser	Data erasure software	To securely erase data from hard drives	\$500 per license
McAfee Total Protection	Antivirus	To detect and protect against malware and other threats	\$30 per user annually
Checkr	Background check software service	To perform background checks for employees, visitors and contractors	\$80 per check
AWS for offsite backup	Cloud storage for backup	To store backup data offsite in the cloud	\$1,200 annually
Snort	Intrusion detection and prevention system	To detect and prevent network threats	\$0 (open source)

knowbe4 security awareness training	Security awareness training platform	To educate employees on cybersecurity threats	\$12 per user annually
Vormetric Data Security	Data encryption and key management	To secure sensitive data with encryption	\$15,000 annually
IBM Resiliency Orchestration	Disaster recovery and business continuity software	To manage disaster recovery and ensure business continuity	\$30,000 annually
Veritas NetBackup	Backup and recovery software	To backup and restore data in case of failure	\$26,000 annually
Windows 10 pro OS	Operating system used on some organization devices.	Used in laptops and desktops.	\$199
Windows 8.1	Operating system used on some organization devices.	Used in laptops and desktops.	\$119
Windows 2016 server	Operating system used on some organization devices.	Used in servers	\$668
Linux OS (Ubuntu and red hat enterprise)	Operating system used on some organization devices.	Used in laptops and desktops.	\$0 (open source)

Table 5. Software assets

7 Asset-weighted factor analysis

Assumption: The impacts on revenue, profitability, and public image have been given to each asset based on how much they would affect these areas if they were compromised. These values are an estimate of how the organization views each asset and what it provides to its operations.

The scale is from 0 – 1 with 0 being no impact and 1 being the highest impact.

Assets	Impact on revenue (30%)	Impact on profitability (40%)	Impact on Public Image (30%)	Weighted Score
Company premises and Staff	1.0	1.0	1.0	100
Critical Information for the organization's operations (Employee information, Financial Records, legal documents)/Physical	1.0	1.0	1.0	100
Critical service of the organization data (SensorDrill, MeasureMe, Shake and Quake)	1.0	1.0	1.0	100
Company Software (SensorDrill, MeasureMe, Shake and Quake)	1.0	1.0	1.0	100
Company Software Data (SensorDrill, MeasureMe, Shake and Quake)	1.0	1.0	1.0	100
Company Software Data	1.0	1.0	1.0	100
Other data not crucial to the organization (visitor data, training data)	1.0	1.0	1.0	100
Company premises and rooms (server room, wiring closets, etc.)	1.0	1.0	1.0	100
Company's major services (SensorDrill, MeasureMe, Shake and Quake)	1.0	1.0	1.0	100

Critical Information for the organization's operations (Employee information, Financial Records, legal documents)	1.0	1.0	1.0	100
Critical service of the organization's data (SensorDrill, MeasureMe, Shake and Quake)	1.0	1.0	1.0	100
Company data	1.0	1.0	1.0	100
Company Software and Database	1.0	1.0	1.0	100
Company premises	1.0	1.0	1.0	100
McAfee Total Protection	0.9	1.0	0.9	94
Domain Controller	0.9	1.0	0.8	91
Company and Third-Party Software	0.9	0.9	0.9	90
Hardware (Servers)	0.9	0.9	0.9	90
Financial Records	0.9	0.9	0.8	87
Shake and Quake Seismic Data	0.9	0.9	0.8	87
IBM Blade Center (multiple instances)	0.9	0.9	0.8	87
HP ProLiant Gen9 Servers	0.9	0.9	0.8	87
Microsoft Azure AD	0.8	0.9	0.8	84
SensorDrill Project Data	0.8	0.9	0.8	84
AWS for Offsite Backup	0.8	0.9	0.8	84
Project 1 Data	0.8	0.9	0.7	81
Physical facilities, hardware, network, etc.	0.9	0.8	0.7	80
Windows 2016 Server	0.8	0.8	0.8	80
The organization's IT/Technical Employees	0.8	0.8	0.8	80

Hardware (Network)	0.8	0.8	0.8	80
Client Contracts and Legal Docs	0.7	0.8	0.8	77
The organization's non-IT staff (Administrative, Finance, Human Resources, Legal Department)	0.8	0.8	0.7	77
Devices and Software	0.8	0.7	0.8	76
Company data, devices, and software	0.7	0.8	0.7	74
Network Configuration Data	0.7	0.8	0.7	74
Hikvision Cameras	0.8	0.8	0.6	74
Backup Data	0.7	0.7	0.8	73
Dell EMC Storage	0.7	0.7	0.8	73
Tape Backup	0.7	0.7	0.8	73
Project 2 Data	0.7	0.8	0.6	71
Employee Records	0.6	0.7	0.8	70
Dell Desktop Computers	0.7	0.7	0.7	70
Hardware (Desktop)	0.7	0.7	0.7	70
Cisco IP Phones	0.7	0.7	0.6	67
LastPass Enterprise	0.5	0.6	0.7	60
VOIP Server	0.5	0.5	0.5	50
Fire Alarms and Smoke Detectors	0.5	0.5	0.5	50
Access Control Badges and Readers	0.3	0.3	0.5	36
Other services not crucial to the organization	0.2	0.2	0.2	20
Visitor and Contractor Badges	0.1	0.1	0.1	10

Table 6. Asset-weighted factor analysis

8 Ranked Risk Vulnerability Assessment Table

Assumptions for vulnerability Assessment table

- The table is based on statistics from the references, to identify the likelihood
- The table is based on logical assumptions from the scenario and the nature of the risk
- Some Assets were grouped into one asset for having the same weightage score and likelihood, and since they were grouped, the weightage increased.

Asset	Weightage Score	Vulnerability	Vulnerability Likelihood	Risk-Rating Factor
Company premises and Staff	100	Wildfire Natural Disaster	1.0	100.0
Financial Records	87	Phishing Attack	0.9	78.3
Critical Information for the organization's operations	100	Absence of Incident Response Plan	0.77	77.0
Critical service of the organization's data	100	Absence of Incident Response Plan	0.77	77.0
Other data not crucial to the organization	100	Absence of Incident Response Plan	0.77	77.0
Microsoft Azure AD	84	Unauthorized Access via Wireless Networks	0.8	67.2
Domain Controller	91	Unauthorized Access via Wireless Networks	0.7	63.7
Employee Records	70	Social Engineering	0.9	63.0

Financial Records	87	Unintentional Data Leakage	0.7	60.9
Company Software (SensorDrill, MeasureMe, Shake and Quake)	100	Data Corruption Due to Software Bugs	0.6	60.0
Company Software Data (SensorDrill, MeasureMe, Shake and Quake)	100	Inconsistent Data Classification and Handling Procedures	0.6	60.0
Company Software Data	100	Lack of Disaster Recovery and Business Continuity Plan	0.5	50.0
Company data, devices, and software	74	Insider Threats	0.76	56.24
Domain Controller	91	Ransomware	0.6	54.6
Client Contracts and Legal Docs	77	Unintentional Data Leakage	0.7	53.9
Shake and Quake Seismic Data	87	Data Corruption Due to Software Bugs	0.6	52.2
Financial Records	87	Social Engineering	0.6	52.2
Network Configuration Data	74	Inconsistent Data Classification and Handling Procedures	0.7	51.8
Company premises and Staff	100	River Flood Natural Disaster	0.5	50.0

Company premises and Staff	100	Urban Flood Natural Disaster	0.5	50.0
Company Software Data	100	Lack of Disaster Recovery and Business Continuity Plan	0.5	50.0
Employee Records	70	Unintentional Data Leakage	0.7	49.0
Employee Records	70	Social Engineering	0.7	49.0
Project 1 Data	81	Data Corruption Due to Software Bugs	0.6	48.6
Project 1 Data	81	Lack of Disaster Recovery and Business Continuity Plan	0.6	48.6
Windows 2016 Server	80	Ransomware	0.6	48.0
Domain Controller	91	Phishing Attack	0.5	45.5
Backup Data	73	Lack of Disaster Recovery and Business Continuity Plan	0.6	43.8
Dell EMC Storage	73	Lack of Disaster Recovery and Business Continuity Plan	0.6	43.8
Tape Backup	73	Ransomware	0.6	43.8
Project 2 Data	71	Data Corruption Due to Software Bugs	0.6	42.6

Microsoft Azure AD	84	Phishing Attack	0.5	42.0
SensorDrill Project Data	84	Inconsistent Data Classification and Handling Procedures	0.5	42.0
Dell Desktop Computers	70	Ransomware	0.6	42.0
Employee Records	70	Data Exposure via Social Media	0.6	42.0
Hardware (Desktop)	70	Equipment Failure	0.6	42.0
Cisco IP Phones	67	Unauthorized Access via Wireless Networks	0.6	40.2
Company Software (SensorDrill, MeasureMe, Shake and Quake)	100	IP Theft	0.4	40.0
Company premises and rooms (server room, wiring closets, etc.)	100	Physical Intrusion	0.4	40.0
Windows 2016 Server	80	Phishing Attack	0.5	40.0
Physical facilities, hardware, network, etc.	80	Incompetent Staff or Team	0.5	40.0
Client Contracts and Legal Docs	77	Lack of Proper Offboarding Procedures	0.5	38.5
Devices and Software	76	Power Outages	0.5	38.0

Backup Data	73	Ransomware	0.5	36.5
Employee Records	70	Phishing Attack	0.5	35.0
Dell Desktop Computers	70	Phishing Attack	0.5	35.0
Critical Information for the organization's operations	100	Lack of Data Backup and Recovery Procedures	0.35	35.0
Critical service of the organization's data	100	Lack of Data Backup and Recovery Procedures	0.35	35.0
Other data not crucial to the organization	100	Lack of Data Backup and Recovery Procedures	0.35	35.0
Cisco IP Phones	67	DoS Attack	0.5	33.5
VOIP Server	50	DoS Attack	0.6	30.0
Company premises and Staff	100	Fire	0.3	30.0
Company's major services	100	Incompetent Staff or Team	0.3	30.0
Network Configuration Data	74	Lack of Proper Offboarding Procedures	0.4	29.6
Tape Backup	73	Lack of Proper Offboarding Procedures	0.4	29.2
Dell Desktop Computers	70	Social Engineering	0.4	28.0

IBM Blade Center (multiple instances)	87	Unauthorized Access to the Physical Server Room	0.3	26.1
Financial Records	87	Data Exposure via Social Media	0.3	26.1
Company data	100	Backup Failures	0.26	26.0
Fire Alarms and Smoke Detectors	50	Lack of Disaster Recovery and Business Continuity Plan	0.5	25.0
VOIP Server	50	Ransomware	0.5	25.0
Project 1 Data	81	Unintentional Data Leakage	0.3	24.3
Company Software and Database	100	SQL Injection Attacks	0.234	23.4
Company and Third- Party Software	90	Outdated Software	0.25	22.5
Access Control Badges and Readers	36	Unauthorized Access via Wireless Networks	0.6	21.6
Project 2 Data	71	Unintentional Data Leakage	0.3	21.3
Employee Records	70	Phishing Attacks	0.3	21.0
The organization's IT/Technical Employees	80	Absence of Incident Response Plan	0.26	20.8
The organization's non-IT staff	77	Lack of Security Awareness and Training	0.26	20.02

Company Software (SensorDrill, MeasureMe, Shake and Quake)	100	XSS (Cross-Site Scripting) Attacks	0.191	19.1
Access Control Badges and Readers	36	Social Engineering	0.5	18.0
Company Software (SensorDrill, MeasureMe, Shake and Quake)	100	Buffer Overflow Attacks	0.15	15.0
Other services not crucial to the organization	20	Incompetent Staff or Team	0.7	14.0
Employee Records	70	Weak Password Policies	0.15	10.5
Company Software (SensorDrill, MeasureMe, Shake and Quake)	100	Unauthorized Software Changes	0.1	10.0
Company premises	100	Landslide Natural Disaster	0.1	10.0
Hardware (Servers)	90	Server Hardware Failures	0.1	9.0
IBM Blade Center (multiple instances)	87	Temperature Rise in Critical Areas	0.1	8.7
HP ProLiant Gen9 Servers	87	Temperature Rise in Critical Areas	0.1	8.7
Project 1 Data	81	Data Exposure via Social Media	0.1	8.1
Hardware (Network)	80	Network Equipment Failure	0.1	8.0

Project 2 Data	71	Data Exposure via Social Media	0.1	7.1
Visitor and Contractor Badges	10	Social Engineering	0.6	6.0
Visitor and Contractor Badges	10	Unauthorized Access via Wireless Networks	0.5	5.0

Table 7. Ranked risk vulnerability assessment

9 Cost Benefit Analysis Table

Hardware and networking components SLE

Asset	Asset Value (USD)	Exposure Factor (%)	SLE (USD)
Dell EMC	3,500	80	2,800
Access Control Badges and Readers	250 each. (250 x 10) 2,500	70	1,000
Hikvision Cameras	350 each. (350 x 30) 10,500	70	7,350
Printmaster Photocopiers and Printers	3,000 (Lease) each. (3,000 x 7) 21,000	60	12,600
Network Cables and Points	2,000	55	1,100
Visitor and Contractor Badges	250	60	150
Fire Alarms and Smoke Detectors	40 each. (40 x 20) 800	50	400
Dell Desktop	400 each. (400 x 200) 80,000	80	64,000
Dell Precision Desktops and Laptops	1,300 each. (1,300 x 250) 325,000	70	227,500
Cisco AP	470 each. (470 x 5) 2,350	70	1,645
Cisco IP	520 each. (520 x 5) 2,600	70	1,820
Cisco Switch (Levels 1 to 5)	200 each. (200 x 5) 1,000	75	750
VOIP Server	900	60	540
Domain Controller	5,500	60	3,300

File & Print Server	5,500	60	3,300
Web Server	5,500	50	2,750
Tape Array	1,400	78	1,092
Voice Gateway	700	65	455
Cisco ISR	3,000	60	1,800
IBM Blade Center (multiple instances)	800 each. (800 x 4) 3,200	55	1,760
Tape Backup	1,400	80	1,120
Cisco Firewall	2,800	80	2,240
Cisco Meraki	2,600	75	1,950

Table 8. Hardware and networking components SLE

Hardware and networking components CBA

- Assumption: **ALE(post-control) = ALE (pre-control) × (1 - 0.65)**

Asset	SLE	ARO (Annual Likelihood)	Pre-ALE (USD)	Post – ALE (USD)	ACS (USD)	CBA (USD)
Access Control Badges and Readers	1,000	60%	600	210	100	290
Printmaster Photocopiers and Printers	12,600	60%	7,560	2646	2,000	2914
Network Cables and Points	1,100	60%	660	231	150	279

Visitor and Contractor Badges	150	60%	90	31.5	30	28.5
Fire Alarms and Smoke Detectors	400	50%	200	70	50	80
Dell Desktop	64,000	10%	6,400	2,240	1,500	2660
Dell Precision Desktops and Laptops	227,500	10%	22,750	7962.5	7,000	7787.5
Cisco AP	1,645	30%	494	172.9	100	221.1
Cisco IP	1,820	10%	182	63.7	50	68.3
Cisco Switch (Levels 1 to 5)	750	60%	450	157.5	150	142.5
VOIP Server	540	10%	54	18.9	10	25.1
Domain Controller	3,300	10%	330	115.5	50	164.5
File & Print Server	3,300	10%	330	115.5	100	114.5
Web Server	2,750	10%	275	96.25	50	128.75
Tape Array	1,092	10%	109	38.15	20	50.85
Voice Gateway	455	60%	273	95.55	100	77.45
Cisco ISR	1,800	30%	540	189	150	201
IBM Blade Center (multiple instances)	1,760	30%	528	184.8	150	193.2
Tape Backup	1,120	30%	336	117.6	80	138.4

Cisco Firewall	2,240	70%	1,568	548.8	500	519.2
----------------	-------	-----	-------	-------	-----	-------

Table 9. Hardware and networking components CBA

Software SLE

Asset	AV (\$)	EF	SLE (\$)
SensorDrill	10,000,000	80%	8,000,000
MeasureMe	12,000,000	80%	9,600,000
Shake and Quake	8,000,000	60%	4,800,000
Project 1	100,000,000	50%	50,000,000
Project 2	30,000,000	40%	12,000,000
Microsoft Office	25,000	70%	17,500
Windows 10	50,000	75%	37,500
Windows server 2016	100,000	85%	85,000

Table 10. Software SLE

Software CBA

- Assumption: $ALE(\text{post-control}) = ALE(\text{pre-control}) \times (1 - 0.40)$

Asset	SLE (\$)	ARO	Pre – ALE (\$)	Post – ALE (\$)	ACS (\$)	CBA (\$)
SensorDrill	8,000,000	60%	4,800,000	2,880,000	400,000	1,520,000
MeasureMe	9,600,000	60%	5,760,000	3,456,000	600,000	1,704,000
Shake and Quake	4,800,000	50%	2,400,000	1,440,000	150,000	810,000
Project 1	50,000,000	35%	17,500,000	10,500,000	1,100,000	5,900,000
Project 2	12,000,000	45%	5,400,000	3,240,000	1,200,000	960,000
Microsoft Office	17,500	40%	7,000	4,200	2,000	800

Windows 10	37,500	55%	20,625	12,375	2,000	6,250
Windows server 2016	85,000	65%	55,250	33,150	5,000	17,100

Table 11. Software CBA

Procedures ALE

Asset	AV (\$)	EF	SLE (\$)
Visitor management procedure	500,000	90%	450,000
Contractor and vendor access procedure	600,000	85%	510,000
Data processing backup procedure	1,000,000	30%	300,000
Server backup procedure	2,000,000	25%	500,000
Server and wiring rooms access control Procedure	1,500,000	35%	525,000
Client PC security procedures	800,000	45%	360,000
Password policy	500,000	40%	200,000
Security auditing procedures	900,000	50%	450,000
Fire evacuation protocols	850,000	85%	722,500
Fire equipment maintenance procedure	700,000	70%	490,000

Table 12. Procedures SLE

Procedures CBA

- Assumption: **ALE(post-control) = ALE (pre-control) × (1 - 0.80)**

Asset	SLE (\$)	ARO	Pre – ALE (\$)	Post – ALE (\$)	ACS (\$)	CBA (\$)

Visitor management procedure	450,000	30%	135,000	27,000	12,000	96,000
Contractor and vendor access procedure	510,000	25%	127,500	25,500	15,000	87,000
Data processing backup procedure	300,000	10%	30,000	6,000	5,000	19,000
Server backup procedure	500,000	15%	75,000	21,000	15,000	39,000
Server and wiring rooms access control Procedure	525,000	20%	105,000	21,000	20,000	64,000
Client PC security procedures	360,000	35%	126,000	25,200	17,000	83,800
Password policy	200,000	20%	40,000	8,000	8,000	24,000
Security auditing procedures	450,000	15%	67,500	13,500	10,000	44,000
Fire evacuation protocols	722,500	45%	325,125	65,025	15,000	245,100
Fire equipment maintenance procedure	490,000	10%	49,000	9,800	8,000	31,200

Table 13. Procedures CBA

CBA PEOPLE ASSET TABLE 1

- **CBA= ALE (pre-control) – ALE (post-control) – ACS**

- Assumption: for critical assets **ALE (post-control) = ALE (pre-control) × (1–0.98)**
for less critical **ALE (post-control) = ALE (pre-control) × (1–0.90).**
- Critical is ALE(pre-control) > 100k, less Critical is ALE(pre-Control) < 100k

Asset	SLE (USD)	ARO	ALE (pre-control)	ACS (USD)	ALE (post-control)	CBA
CEO	12,000,000	0.10	1,200,000	10,931	24,000	1,165,069
Chief Information Officer	4,000,000	0.05	200,000	26,661	4,000	169,339
Chief Security Officer	5,400,000	0.05	270,000	26,660	5,400	237,940
Division Head - R&D	3,000,000	0.07	210,000	26,660	4,200	179,140
Division Head - Software	3,150,000	0.07	220,500	26,660	4,410	189,430
Division Head - Data Processing	4,500,000	0.07	315,000	26,660	6,300	282,040
Manager - Human Resources	450,000	0.30	135,000	10,931	13,500	110,569
Manager - Finance	750,000	0.20	150,000	10,931	4,500	134,569
IT Staff	520,000	0.10	52,000	26,660	5,200	20,140
R&D Staff	2,250,000	0.15	337,500	26,660	13,500	297,340

Data Processing Staff	1,050,000	0.20	210,000	26,660	21,000	162,340
Technical Support Staff	450,000	0.15	67,500	26,660	13,500	27,340
Other Staff	1,020,000	0.45	459,000	26,660	45,900	386,440
Contractors	300,000	0.05	15,000	500	1,500	13,000

Table 14. People CBA

CBA DATA ASSET TABLE 2

- **CBA = ALE (pre-control) – ALE (post-control) – ACS**

Asset	SLE (USD)	ARO	ALE (pre-control)	ACS	ALE (post-control)	CBA
SensorDrill Data	27,000,000	30%	8,100,000	30,000	1,620,000	6,450,000
MeasureMe Data	27,000,000	30%	8,100,000	30,000	1,620,000	6,450,000
Shake and Quake Seismic Data	10,000,000	30%	3,000,000	30,000	600,000	2,370,000
Employee Information	1,500,000	50%	750,000	15,000	262,500	472,500
Financial Records	9,000,000	40%	3,600,000	25,000	720,000	2,855,000
Client Contracts and Legal Docs	5,600,000	30%	1,680,000	25,000	336,000	1,319,000
Backup Data	25,000,000	5%	1,250,000	10,000	250,000	990,000

Network Configuration Data	7,200,000	7%	504,000	5,000	100,800	398,200
Archived Seismic Data Reports	4,800,000	45%	2,160,000	30,000	756,000	1,374,000
Vendor Agreements	2,100,000	40%	840,000	20,000	294,000	526,000
Employee Training Records	1,000,000	5%	50,000	1,000	17,500	31,500
Visitor Data	150,000	3%	4,500	200	1,575	2,725

Table 15. Data CBA

10 Risk Control Strategy

Hardware and Networking Components Risk control strategy

Asset	Threat	Defense	Transferal	Mitigation	Acceptance	Termination	Explanation
Domain Controller	Unauthorized Access via Wireless Networks	✓	✓	✓			Wireless network access is crucial for operations. Defense and mitigation secure access, and transferal covers

							financial loss risks. Mitigation includes using Cisco Meraki MR56 for secure wireless access, Aruba ClearPass for real-time monitoring, and deploying MFA with Okta Identity Cloud for access security.
	Ransomware	✓	✓	✓			Defense prevents ransomware, while secure backups and insurance mitigate financial and operational impacts. Deploy Sophos Intercept X with EDR for ransomware detection and automated backups using Dell EMC Data Domain 3300 to ensure data recovery(

	Phishing Attack	✓		✓			Phishing attacks are mitigated through training and advanced email filtering systems. Use Barracuda Email Security Gateway for phishing email filtering and conduct regular staff training on phishing identification
Cisco IP	Unauthorized Access via Wireless Networks	✓		✓			Defense secures wireless networks, while regular audits ensure vulnerabilities are mitigated effectively. Utilize Cisco Firepower for IDS/IPS and WPA3 encryption for wireless networks alongside quarterly wireless audits

							using Ekahau Pro.
	DoS Attack	✓		✓			Defense strategies handle network-based DoS attacks to ensure minimal disruption to communications. Protect against DoS using Cisco Firepower 1120 appliances for real-time traffic monitoring and rate limiting via Cloudflare.
VOIP Server	DoS Attack	✓		✓			Defense minimizes disruptions from DoS attacks, complemented by mitigation tools to manage traffic spikes. Configure secure SIP trunks and use Cisco Firepower with rate limiting to

							mitigate DoS effects.
	Ransomware	✓		✓			Endpoint protection blocks ransomware, and backups restore the system without needing ransom payments. Use Sophos Intercept X for endpoint security and Dell EMC Data Domain for secure backups.
Dell EMC	Lack of DRP and BCP	✓		✓			A comprehensive DRP ensures recovery from disasters, while offsite redundancy protects against localized issues. Implement automated backups with Dell EMC Data Domain 3300 and conduct

							regular recovery tests.
	DoS Attack	✓		✓			Real-time monitoring and mitigation tools effectively handle DoS threats, ensuring data availability. Use Cisco Firepower for real-time DoS detection and traffic shaping.
	Unauthorized Access via Wireless Networks	✓		✓			Defense ensures wireless networks are secure, minimizing unauthorized access risks to backup devices. Mitigation involves WPA3 encryption for wireless access and Aruba ClearPass for unauthorized access prevention.

Access Control Badges and Readers	Unauthorized Access via Wireless Networks	✓		✓			Secure access controls and regular audits prevent unauthorized use of access systems. Implement Aruba ClearPass and segment guest networks to reduce access risks.
	Social Engineering	✓		✓			Awareness training reduces social engineering risks, and background checks reduce insider threats. Deploy HID Global iCLASS SE Readers for secure badge access and conduct awareness training to reduce risks.
Tape Backup	Ransomware	✓		✓			Defense encrypts backups to prevent ransomware, while secure storage

							ensures physical protection. Utilize encrypted backups with Dell EMC Data Domain 3300 stored offline.
	Lack of Proper Offboarding Procedures	✓		✓			Automated offboarding minimizes residual risk, and secure wiping protects sensitive data from unauthorized recovery. Implement automated offboarding processes with secure data wiping using BitLocker.
Dell Desktop	Ransomware	✓		✓			Endpoint protection and backups minimize disruption from ransomware attacks. Protect endpoints with Sophos

							Intercept X and maintain secure backups.
	Phishing Attack	✓		✓			Employees learn to recognize phishing attempts, and email filtering blocks suspicious messages. Use Barracuda Email Security Gateway for filtering and conduct training.
	Social Engineering	✓		✓			Training prepares employees to handle social engineering threats, while email verification reduces phishing risks. Conduct social engineering simulations and implement strict email verification protocols

Visitor and Contractor Badges	Social Engineering	✓		✓			Defense mechanisms ensure visitors and contractors follow security protocols to reduce social engineering risks.
	Unauthorized Access via Wireless Networks	✓		✓			Defense and mitigation reduce risks associated with wireless network exploitation by unauthorized visitors or contractors. Deploy separate guest networks using Cisco Meraki MR56 and enforce Aruba ClearPass monitoring.
Fire Alarms and Smoke Detectors	Lack of DRP and BCP	✓		✓			A robust DRP ensures recovery from disasters, while testing ensures fire equipment reliability.

Cisco Firewall	Configuration errors, bypassing due to misconfigured rules, DDoS attacks, insider misuse, and firmware vulnerabilities.	✓		✓			Use Cisco Firepower 1120 for traffic analysis and schedule regular firmware updates.
File & Print Server	Unauthorized data access, malware/ransomware attacks, data corruption due to hardware failure.	✓		✓			Restrict file server access using role-based permissions. Use role-based permissions with Microsoft Azure AD and Dell EMC for backup recovery.
Web Server	Cross-Site Scripting (XSS), SQL injection, distributed denial-of-service (DDoS) attacks	✓		✓			Secure with firewalls and web application firewalls (WAFs) to block malicious traffic. Monitor for vulnerabilities and patch systems regularly to reduce risk. Secure

							applications using Cloudflare WAF and perform regular vulnerability scans with Acunetix.
Tape Array	Physical theft, unauthorized access to unencrypted data	✓		✓			Store tapes securely in an offsite location to prevent theft or damage. Use encryption to protect data stored on tapes from unauthorized access.
Voice Gateway	Eavesdropping, toll fraud, unauthorized SIP trunk access, and DoS attacks on voice traffic.	✓		✓			Configure secure protocols to prevent interception of voice traffic. Maintain firmware updates and monitor logs for suspicious activity.
Cisco ISR	Routing table poisoning, interception of unencrypted data, unauthorized	✓		✓			Use intrusion prevention systems (IPS) to detect and block threats.

	configuration changes						Implement traffic rate limiting to prevent DoS attacks.
IBM Blade Center (multiple instances)	Physical theft or tampering, overheating due to cooling failures, and firmware attacks.	✓		✓			Secure physical access to blade servers and implement network segmentation. Monitor server performance and use redundant systems for high availability.
Printmaster Photocopiers and Printers	Unauthorized access to stored print jobs, exploitation via unpatched firmware, and misuse for data exfiltration.	✓	✓				Implement authentication for print jobs to prevent unauthorized use. Transferal: Rely on printmaster Pty Ltd agreements to transfer maintenance and security responsibilities to the vendor.

Network Cables and Points	Physical tampering (e.g., tapping cables for eavesdropping), accidental damage, power surges, and cable mismanagement causing service interruptions.	✓		✓			Use secure cable management and regular inspections to prevent physical tampering or damage. Employ surge protection and redundancy to minimize the impact of cable failures.
Cisco AP	Rogue access points, unauthorized access due to weak Wi-Fi encryption, signal jamming, and man-in-the-middle attacks on Wi-Fi traffic.	✓		✓			Implement WPA3 encryption for secure wireless access. Use intrusion detection systems to monitor unauthorized access attempts.
Cisco Switch (Levels 1 to 5)	VLAN hopping attacks, misconfigured access control lists (ACLs), firmware vulnerabilities, and physical tampering of switch ports.	✓		✓			Use access control lists (ACLs) and VLANs to segment traffic securely. Regular firmware updates and real-time

							traffic monitoring with tools like Cisco Firepower.
--	--	--	--	--	--	--	---

Table 16. Hardware and networking components risk control strategy

Software and Procedure Risk control strategy

Assets	Threat	Defense	Transferal	Mitigation	Acceptance	Explanation
Software (SensorDrill, MeasureMe, Shake and Quake, Project 1, Project 2)	Software vulnerabilities	✓		✓		Defense: Using cisco firewalls and snort IDS to detect and prevent SQL injection, buffer overflows and XSS attacks. Using role based access control to prevent unauthorised employees and users from accessing source code and software data. Mitigation: Using tape and server backups alongside veritas netbackup software and AWS cloud storage backups to store critical software source code and data.
	SQL injection	✓		✓		Defense: Using parameterized queries to prevent SQL statements from being accepted as user input.

						Deploying Azure web application firewalls to filter, monitor and block malicious SQL queries before they reach the database. Mitigation: Having backup databases in case the main database being compromised.
	Buffer overflow	✓		✓		Defense: Implement bound checking and input validation in the source code. Placing stack canaries in the memory to detect buffer overflow attacks. Mitigation: Having local and cloud backups in place to restore application operations.
Windows 10	Software vulnerabilites	✓		✓		Defense: Using windows defender and mcafee antivirus to protect the OS from viruses and other malwares. Mitigation: Creating secure backup copies of the OS.
Windows 8.1	Software vulnerabilites	✓		✓		Defense: Using windows defender and mcafee antivirus to protect the OS from viruses and other malwares. Mitigation: Creating secure backup copies of the OS.
Linux (RedHat and Ubuntu)	Software vulnerabilites	✓		✓		Defense: mcafee antivirus to protect the OS from viruses and other malwares.

						Mitigation: Creating secure backup copies of the OS.
Password policies	Weak password policies	✓		✓		Defense: Enforcing mandatory password changing policies. Mitigation: Locking out employee accounts if the passwords are not changed regularly or if the accounts are compromised.
Office premises	Fire hazards	✓		✓		Defense: Installing fire extinguishers and sprinklers across the office premises. Creating fire evacuation drills and protocols to ensure employees are aware of what steps to take. Mitigation: Using the fire evacuation protocols and safety training to mitigate the damage caused by fire outbreaks.
	Physical intrusion	✓		✓		Defense: Locking important server and employee rooms using RFID locks. Supervising and escorting visitors and contractors through the premises using security guards. Surveillance of the premises using CCTV cameras. Mitigation: If physical intruders manage to access sensitive areas of the organisation and tamper with devices and data,

						Use tape and server backups alongside veritas netbackup software and AWS cloud storage backups to store the critical project source code and data to minimise losses and damage.
	Insider attacks	✓		✓		Defense: Using checkr for background checking to ensure only reliable and trustworthy employees are hired. Surveillance of the premises using CCTV cameras to monitor any suspicious activities. Mitigation: Implement role-based access control using Microsoft Azure AD and principle of least privilege to prevent unauthorised access and minimise damage caused by rogue employees.
	Power outages			✓		Mitigation: Set up backup generators and UPS to continue operations during power failures or outages.
	Natural disasters			✓	✓	Mitigation: Setting up hot sites or cold sites to relocate operations. Using evacuation drills and protocols to minimise the damage. Acceptance: If the damage is too severe, then the only option is to accept the risk.

Employees	Phishing attacks and social engineering	✓		✓		Defense: Using mail filters to filter out spam and possible phishing emails. Educating employees and providing training to identify phishing attacks using cofense phishme software simulations and training programs from knowbe4. Mitigation: Using role based access control and multi factor authentication to minimise damage caused by employee accounts compromised due to phishing.
-----------	---	---	--	---	--	--

Table 17. Software and procedures risk control strategy

Data Assets Risk control strategy

Assets	Threat	Defense	Transferral	Mitigation	Acceptance	Termination	Explanation
SensorDrill Data, MeasureMe Data,	Unauthorized Access/data corruption/data leakage	✓		✓			Defense: Role-based access control (RBAC), encryption, and Cisco Firewalls and Snort IDS to prevent software threats. Conduct rigorous code reviews and testing protocols to identify and eliminate

							vulnerabilities and bugs. Mitigation: Use Veritas NetBackup and AWS Cloud Backup for disaster recovery.
	Natural Disasters			✓	✓		Mitigation: Backups on AWS and Veritas NetBackup to protect data. Acceptance: Partial acceptance for minor recovery delays from natural disasters.
	Human Error/ Phishing/Social Engineering	✓		✓			Defense: Implement advanced email security solutions like Barracuda Email Security Gateway and Mimecast Secure Email Gateway to filter phishing emails. Utilize multi-factor

							authentication (MFA). Encrypt sensitive employee data at rest and in transit. Mitigation: Provide regular phishing awareness and social engineering training through SETA programs and Cofense PhishMe.
Shake and Quake Data	Unauthorized Access/data corruption/ data leakage	✓		✓			Defense: Role-based access control (RBAC), encryption, and Cisco Firewalls and Snort IDS to prevent software threats. Conduct rigorous code reviews and testing protocols to identify and eliminate vulnerabilities. Mitigation: Use

							AWS Cloud Backup and McAfee Total Protection to secure data.
	Natural Disasters			✓	✓		Mitigation: Backups on AWS and Veritas NetBackup to protect data. Acceptance: Partial acceptance for minor recovery delays from natural disasters.
	Human Error/ Phishing/Social Engineering						Defense: Implement advanced email security solutions like Barracuda Email Security Gateway and Mimecast Secure Email Gateway to filter phishing emails. Utilize multi-factor authentication (MFA). Encrypt sensitive employee data at rest and in

							transit. Mitigation: Provide regular phishing awareness and social engineering training through SETA programs and Cofense PhishMe .
Employee Information	Unauthorized Access/data corruption/ data leakage	✓		✓			Defense: Provide extensive phishing awareness training using SETA programs. Mitigation: Enable multi-factor authentication (MFA) to access sensitive employee data.
	Human Error/ Phishing/Social Engineering	✓		✓			Defense: Implement advanced email security solutions like Barracuda Email Security Gateway and Mimecast Secure Email

							Gateway to filter phishing emails. Utilize multi-factor authentication (MFA). Encrypt sensitive employee data at rest and in transit. Mitigation: Provide regular phishing awareness and social engineering training through SETA programs and Cofense PhishMe.
Financial Records	Unauthorized Access/data corruption/ data leakage	✓		✓			Defense: Advanced intrusion detection systems like Cisco Firewalls. Mitigation: Encrypt data and use Veritas NetBackup for secure storage.
	Human Error/ Phishing/Social Engineering	✓		✓			Defense: Implement advanced email security solutions like

							Barracuda Email Security Gateway and Mimecast Secure Email Gateway to filter phishing emails. Utilize multi-factor authentication (MFA). Encrypt sensitive employee data at rest and in transit. Mitigation: Provide regular phishing awareness and social engineering training through SETA programs and Cofense PhishMe
Client Contracts and Legal Docs	Unauthorized Access/data corruption/ data leakage	✓		✓			Defense: Restrict access using Microsoft Azure AD to ensure only authorized individuals can access sensitive legal documents. Mitigation: Implement

							regular access audits and encryption for compliance.
Archived Seismic Data Reports	Human Error/ Phishing/Social Engineering	✓		✓			Defense: Implement advanced email security solutions like Barracuda Email Security Gateway and Mimecast Secure Email Gateway to filter phishing emails. Utilize multi-factor authentication (MFA). Encrypt sensitive employee data at rest and in transit. Mitigation: Provide regular phishing awareness and social engineering training through SETA programs and Cofense PhishMe
	Natural Disaster			✓		✓	Mitigation: Backups on AWS and

							Veritas NetBackup to protect data. Acceptance: Partial acceptance for minor recovery delays from natural disasters.
	Insider threats	✓		✓			Defense: Implement Role-Based Access Control (RBAC) to limit access to sensitive data based on job roles. Use Microsoft Azure AD and Okta Identity Cloud to monitor user activities and enforce identity-based access policies. Mitigation: Regularly monitor employee behavior with tools like Splunk to

							detect anomalies.
Employee Training Records	Unauthorized Access	✓		✓			Defense: Enforce offboarding compliance audits. Mitigation: Use Blancco Drive Eraser to delete sensitive data securely during employee offboarding.
Backup Data	Unauthorized Access/data corruption/ data leakage	✓		✓			Defense: Implement tape and server backups as additional safety layers. Mitigation: Use Veritas NetBackup and AWS Cloud storage to ensure data integrity and redundancy.
	Natural Disasters			✓	✓		Mitigation: Backups on AWS and Veritas NetBackup to protect data. Acceptance: Partial

							acceptance for minor recovery delays from natural disasters.
Physical Data	Physical Intrusion	✓		✓			Defense: Physical access controls such as badges and visitor logging systems. Mitigation: Conduct regular access audits and monitor visitor logs for anomalies.

Table 18. Data Risk Control Strategy

People Assets Risk control strategy

Assets	Threat	Defense	Transferral	Mitigation	Acceptance	Termination	Explanation
Top positions in the organization	Human Error/ Phishing/Social Engineering	✓		✓			Defense: Enforce strict access controls and conduct extensive background checks for executives. Mitigation: Implement SETA programs and phishing awareness training tailored

							to high-ranking positions.
Technical Departments	Human Error/ Phishing/Social Engineering	✓		✓			Defense: Deploy advanced intrusion detection systems(snort) for technical teams. Mitigation: Use tools like Splunk to monitor and log real-time activity.
	Insider threats	✓		✓			Defense: Implement Role-Based Access Control (RBAC) to limit access to sensitive data based on job roles. Use Microsoft Azure AD and Okta Identity Cloud to monitor user activities and enforce identity-based access policies.

							Mitigation: Regularly monitor employee behavior with tools like Splunk to detect anomalies.
Other Departments (Finance, HR)	Human Error/ Phishing/Social Engineering	✓		✓			Defense: Train employees on secure handling of sensitive data and compliance policies using SETA programs and phishing awareness. Mitigation: Use encryption and access restrictions for departmental files based on roles and responsibilities.

Table 19. People Risk Control Strategy

References

Access Rights Manager (ARM) Software | SolarWinds. (n.d.).
<https://www.solarwinds.com/access-rights-manager>

Acunetix. (2024, July 22). Acunetix | Web Application and API Security Scanner.
<https://www.acunetix.com/>

Ahmed, A. E. (2018). *Enhanced Identification Model to Improve Data Leakage Prevention Systems in Oil and Gas Industry*.

Alrawi, L. N., & Pusatli, T. (2020, April). Investigating end user errors in oil and gas critical control systems. In *Proceedings of the 2020 6th International Conference on Computer and Technology Applications* (pp. 41-45).

Alsop, T. (2014, February 1). Servers - annual failure rates. Statista.
<https://www.statista.com/statistics/430769/annual-failure-rates-of-servers/#:~:text=Where%20a%20four%20year%2Dold,and%20management%20costs%20over%20time.>

Arcserve. (2013, September 26). Which hardware fails the most and why. Arcserve.
<https://www.arcserve.com/blog/which-hardware-fails-most-and-why>

Australia - risk index for natural disasters 2021 | Statista. (2024, April 3). Statista. <https://www.statista.com/statistics/937597/australia-risk-index-for-natural-disasters/>

Backup As A Service - AWS Backup - AWS. (n.d.). Amazon Web Services, Inc. <https://aws.amazon.com/backup/>

Barracuda Email Security Gateway 300 | BarraGuard.com. (n.d.). https://www.barraguard.com/300.asp?srsltid=AfmBOorRCCxN5MWWjuvXOn4Z7ODreG5_W2n1FFyzN7tETIUV3WAb7jqD

Bugzilla. (n.d.). Bugzilla. <https://www.bugzilla.org/>

Checkr. (2024, October 16). Checkr – Employee Background Screening for Companies. Checkr – Employee Background Screening for Companies. <https://checkr.com/>

Cisco Firepower 1000 Series Data Sheet. (2023, October 23). Cisco. <https://www.cisco.com/c/en/us/products/collateral/security/firepower-1000-series/datasheet-c78-742469.html>

Cisco Meraki. (2023, October 2). WiFi 6 Wireless Indoor Access Point | 802.11ax | MR56 | Cisco Meraki. <https://meraki.cisco.com/product/wi-fi/indoor-access-points/mr56/>

Cofense. (n.d.). PhishMe Security Awareness Training (SAT) Platform | Cofense. PhishMe Security Awareness Training (SAT) Platform | Cofense. [https://cofense.com/phishme-security-awareness-training-\(sat\)-platform](https://cofense.com/phishme-security-awareness-training-(sat)-platform)

CoolIT Systems. (2024, July 25). CoolIT Systems | Liquid Cooling Technology. <https://www.coolitsystems.com/>

CXtec. (2024, July 8). Surprising truth about network hardware failures. Cxtec. <https://www.cxtec.com/blog/network-hardware-failures-shocking-truth/>

CyberPower Systems. (2019, January 16). CyberPower UPS Systems, Battery Backup, PDUs, USB Surge Protectors. CyberPower. <https://www.cyberpowersystems.com/>

Dell. (n.d.). Dell PowerProtect DD3300. Dell. <https://www.dell.com/en-us/shop/ipovw/data-domain-3300>

Digital. (2024, October 16). Blancco Drive Eraser – Our Premier Data Erasure Solution. Blancco. <https://www.blancco.com/products/drive-eraser/>

Enterprise IT World. (2024, January 25). From 2019 to 2024, the Number of Insider Attacks Increased from 66% of Organizations to 76%. <https://www.enterpriseitworld.com/from-2019-to-2024-the-number-of-insider-attacks-increased-from-66-of-organizations-to-76/>

Enterprise Password Management Solutions - LastPass. (n.d.). <https://www.lastpass.com/solutions/enterprise-password-management>

Fire & Safety UAE, National Fire Fighting Manufacturing Company. (n.d.). <https://www.naffco.com/>

Hagan, J. (2024, September 25). 7 Essential Data Backup and Recovery Statistics for the Year 2024. Teledata Select. <https://teledataselect.com/7-essential-data-backup-and-recovery-statistics-for-the-year-2024/>

HID® iCLASS® SE Readers. (n.d.). HID. <https://www.hidglobal.com/product-mix/iclass-se-readers>

IBM Resilient Security Orchestration, Automation and Response Platform_SaaS - Divestiture notification. (n.d.). <https://www.ibm.com/support/pages/node/7109909>

In-depth industry outlook: Oil and Gas Software Market Size & Forecast. Verified Market Research. (2024, September 20). <https://www.verifiedmarketresearch.com/product/oil-and-gas-software-market/>

Kaspersky. (2023). How cybercrime is impacting SMBs in 2023. In SecureList Kaspersky. Securelist. <https://securelist.com/smb-threat-report-2023/110097/>

Khaled, M. (2024, May 5). Revealing the unnerving social media hacking statistics for 2024: ProfileTree. ProfileTree Web Design and Digital Marketing. <https://profiletree.com/exposing-unnerving-social-media-hacking-statistics/>

Live Confidently Online with McAfee Total Protection. (n.d.). McAfee. <https://www.mcafee.com/en-us/antivirus/mcafee-total-protection.html>

Microsoft Entra ID (formerly Azure Active Directory) | Microsoft Security. (n.d.). <https://www.microsoft.com/en-us/security/business/identity-access/microsoft-entra-id>

Millions of people use the Okta Identity Cloud. (n.d.). Okta, Inc. <https://www.okta.com/learn/okta-identity-cloud/>

Mutalib, M. M. A., Zainol, Z., & Halip, M. H. M. (2021, December). Mitigating Malware Threats at Small Medium Enterprise (SME) Organisation: A Review and Framework. In 2021 6th IEEE International Conference on Recent Advances and Innovations in Engineering (ICRAIE) (Vol. 6, pp. 1-6). IEEE.

Nagios. (2024, November 14). Nagios Core Services Platform | Nagios Open Source. Nagios Open Source. <https://www.nagios.org/>

NetBackup: #1 in enterprise backup solutions. (n.d.). Veritas. <https://www.veritas.com/protection/netbackup>

NetBotz. (n.d.). APC. <https://www.apc.com/us/en/product-range/61830-netbotz/#overview>

Önen, D. (2024, May 24). What are the Cybersecurity Risks Associated with Outdated Software and Operating Systems? Easy2Patch. <https://www.easy2patch.com/blog/cybersecurity-risks-outdated-software-systems>

Pangarkar, T. (2024, August 1). Physical Security Statistics 2024 By Crucial Element for Protection. Market.us Scoop. <https://scoop.market.us/physical-security-statistics/>

Ponemon Report: The State of Offensive Security. (2023, September 19). Bishop Fox. <https://bishopfox.com/ponemon-2023-report>

Pro Series (All). (n.d.). Hikvision. <https://www.hikvision.com/en/products/IP-Products/Network-Cameras/Pro-Series-EasyIP-/?category=Network+Products&subCategory=Network+Cameras&series=Pro+Series+%28All%29&checkedSubSeries=NONE>

Saxena, A. (2024, November 7). 100+ phishing attack statistics you should know in 2024. Sprinto. <https://sprinto.com/blog/phishing-statistics/>

Security Awareness Training | KnowBe4. (n.d.). <https://www.knowbe4.com/>

Selenium. (n.d.). Selenium. <https://www.selenium.dev/>

Sobers, R. (2024, September 13). 157 cybersecurity statistics and trends [updated 2024]. Varonis. <https://www.varonis.com/blog/cybersecurity-statistics>

Sophos Endpoint Protection. (n.d.). Sophos. <https://www.sophos.com/en-us/products/endpoint-antivirus>

Splunk | The Key to Enterprise Resilience. (n.d.). Splunk. <https://www.splunk.com/>

Statista. (2024, February 20). Global web application critical vulnerability taxonomy 2023. <https://www.statista.com/statistics/806081/worldwide-application-vulnerability-taxonomy/>

Stergiopoulos, G., Gritzalis, D. A., & Limnaios, E. (2020). Cyber-attacks on the Oil & Gas sector: A survey on incident assessment and attack patterns. *IEEE Access*, 8, 128440-128475.

Stouffer, C. (2024, March 26). 139 password statistics to help you stay safe in 2024. Norton. <https://us.norton.com/blog/privacy/password-statistics>

The Failure of Backups and Restores: A Growing Concern in Data Management. (n.d.). <https://info.cloudcarib.com/blog/backup-failures>

Vormetric Data Security Platform | Thales. (n.d.). <https://cpl.thalesgroup.com/encryption/vormetric-data-security-platform>

What are social engineering attacks? A detailed explanation | Splunk. (n.d.). Splunk. https://www.splunk.com/en_us/blog/learn/social-engineering-attacks.html

Yadav, R. (2024, August 23). 26% of organizations lack security training, leaving them vulnerable. Threatcop. <https://threatcop.com/blog/26-of-organizations-lack-security-training-leaving-them-vulnerable/>

Your Integrity Management Ally. (n.d.). <https://www.tripwire.com/>

2023 Data Breach Investigations Report: Frequency and cost of social engineering attacks skyrocket. (2023, August 9). News Release | Verizon. <https://www.verizon.com/about/news/2023-data-breach-investigations-report>